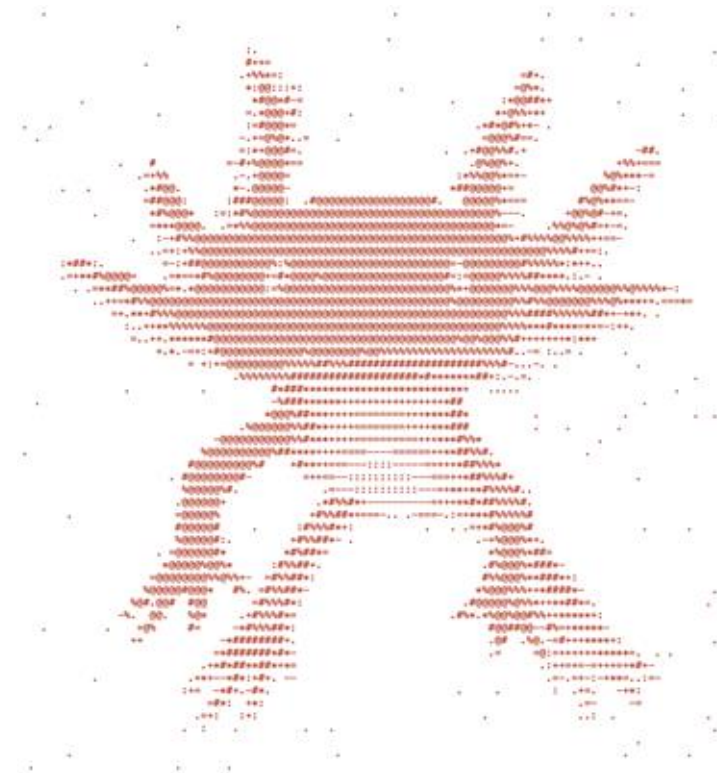


If the Adversary Lives Off Your Land, So Should You

Going beyond **Adversary eXposure** while
Obviating them in **Living Off The Land**
(AXOLOTL)



Meet the Speakers



Shane Steiger, Esq., CISSP
Principal Cyber Security Engineer
Cyber Resiliency Team & Engage Team



Maretta Morovitz
Department Manager Digital Investigations
Cyber Denial, Deception,
and Adversary Engagement & Engage Team

Briefing Flow

**What is Adversary Engagement
and Why Does it Matter?**

01



How Do We Advance Beyond
“Deception for Detection”?

02

How Are We Working to Enable
Advanced Adversary Engagement at
Scale?

03

An open-source framework, AXOLOTL, to
explore adversary engagement in your
environment today

04

Before We Begin...

Prepare	Expose		Affect			Elicit		Understand
Plan	Collect	Detect	Prevent	Direct	Disrupt	Reassure	Motivate	Analyze
Cyber Threat Intelligence	API Monitoring	Introduced Vulnerabilities	Baseline	Attack Vector Migration	Isolation	Application Diversity	Application Diversity	Cyber Threat Intelligence
Engagement Environment	Network Monitoring	Lures	Hardware Manipulation	Email Manipulation	Lures	Artifact Diversity	Artifact Diversity	After-Action Review
Gating Criteria	Software Manipulation	Malware Detonation	Isolation	Introduced Vulnerabilities	Network Manipulation	Burn-In	Information Manipulation	Threat Model
Operational Objective	System Activity Monitoring	Network Analysis	Network Manipulation	Lures	Software Manipulation	Email Manipulation	Introduced Vulnerabilities	
Persona Creation			Security Controls	Malware Detonation		Information Manipulation	Malware Detonation	
Storyboarding				Network Manipulation		Network Diversity	Network Diversity	
Threat Model				Peripheral Management		Peripheral Management	Personas	
				Security Controls		Pocket Litter		
				Software Manipulation				

We will not focus on Engage in this talk, but you can visit engage.mitre.org to learn more.

Before We Begin...

Prepare	Expose		Affect			Elicit		Understand
Plan	Collect	Detect	Prevent	Direct	Disrupt	Reassure	Motivate	Analyze
Class Threat Intelligence	APT Monitoring	Endpoint Intelligence	Network	Attack Vector Intelligence	Network	Reputation Strategy	Reputation Strategy	Class Threat Intelligence
Threat Intelligence	Malware Monitoring	Log	Network Monitoring	Cloud Monitoring	Log	Malware Strategy	Malware Strategy	Malware Analysis
Living Threat	Offense Management	Malware Detection	Network	Endpoint Intelligence	Malware Management	Malware	Malware Management	Threat Intel
Operational Capabilities	System Activity Monitoring	Network Analysis	Malware Management	Log	Offense Management	Cloud Management	Endpoint Intelligence	
Resource Creation			Security Controls	Malware Intelligence		Malware Management	Malware Detection	
Interpreting				Malware Management		Malware Strategy	Malware Strategy	
Threat Intel				Cloud Intelligence		Endpoint Management	Endpoint	
				Malware Management		Threat Log		

We will not focus on Engage in this talk, but you can visit engage.mitre.org to learn more.

Everyone thought Helms Deep was impenetrable...



Because no one paid attention to this



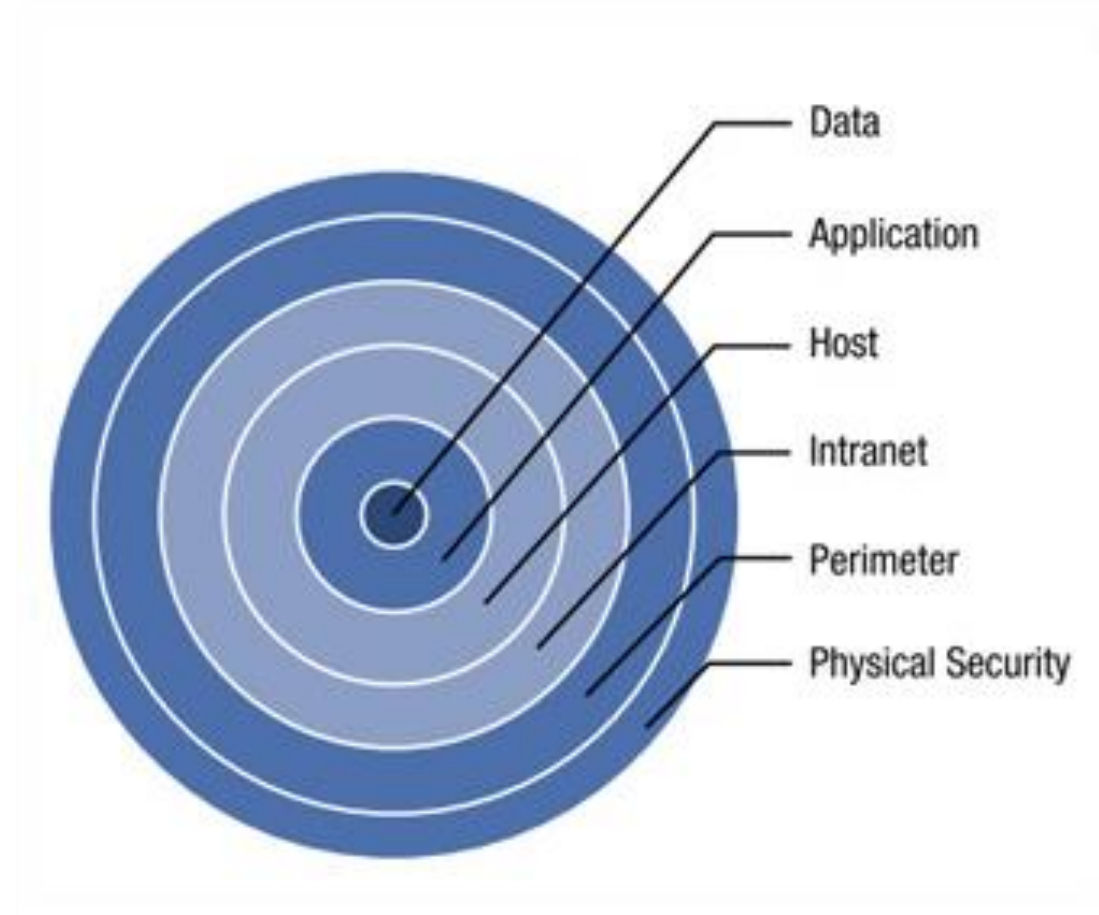
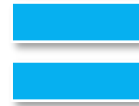
But do you remember this guy?



And then this...



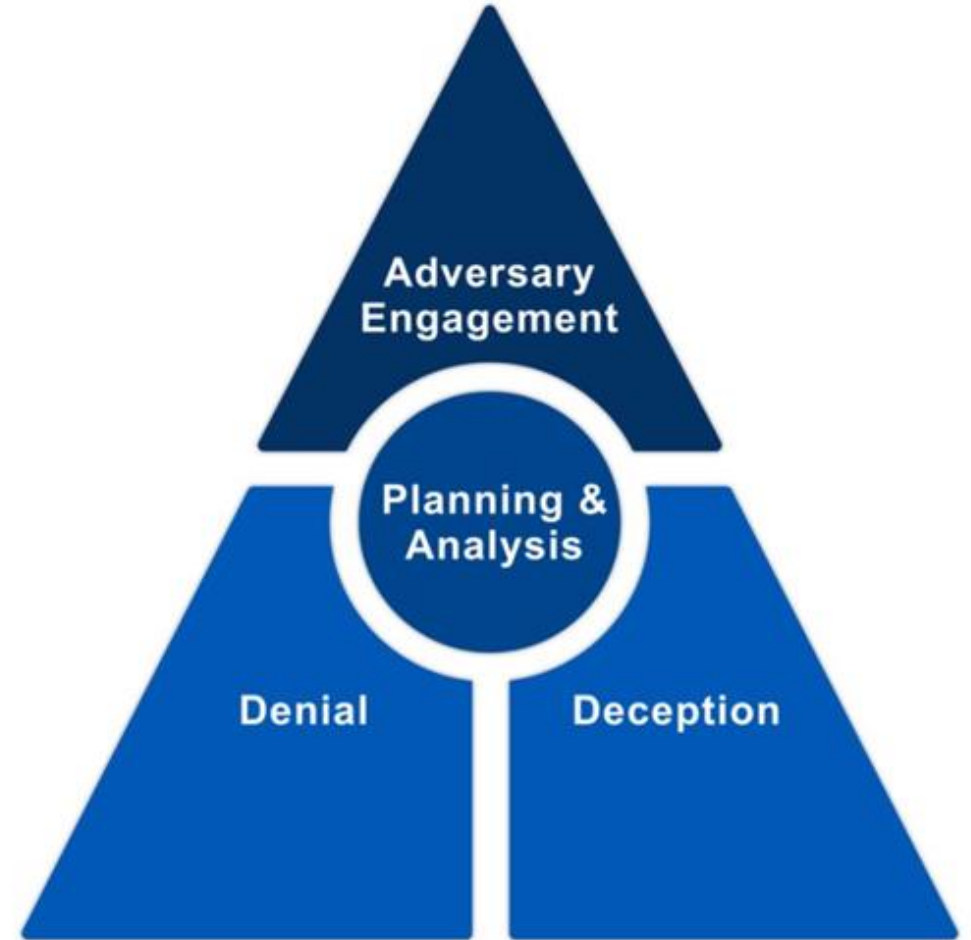
Defense-in-Depth: Our Helm's Deep



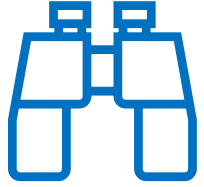
Cyber Denial: conceal facts and fictions to create ambiguity about what is or is not real.

Cyber Deception: reveal facts and fictions to create and reinforce perceptions and beliefs.

When used together with **strategic planning and analysis**, they provide the pillars of **Adversary Engagement**.



The Goals of Adversary Engagement



Expose adversaries

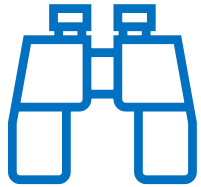


Negatively **Affect** adversaries' cyber operations



Elicit intelligence from adversaries

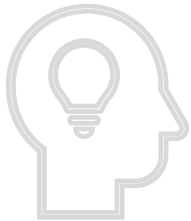
Most people start here.



Expose adversaries



Negatively **Affect** adversaries' cyber operations



Elicit intelligence from adversaries

Briefing Flow

What is Adversary Engagement
and Why Does it Matter?

01

**How Do We Advance Beyond
“Deception for Detection”?**

02

How Are We Working to Enable
Advanced Adversary Engagement at
Scale?

03

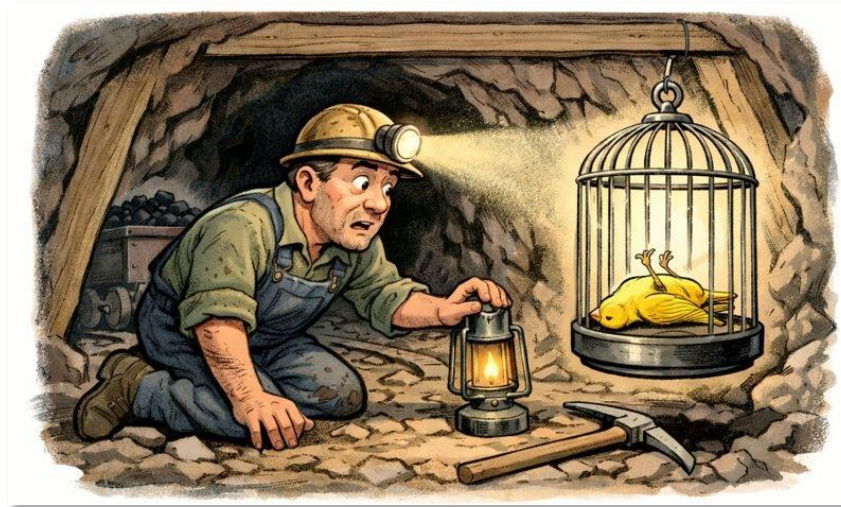
An open-source framework, AXOLOTL, to
explore adversary engagement in your
environment today

04

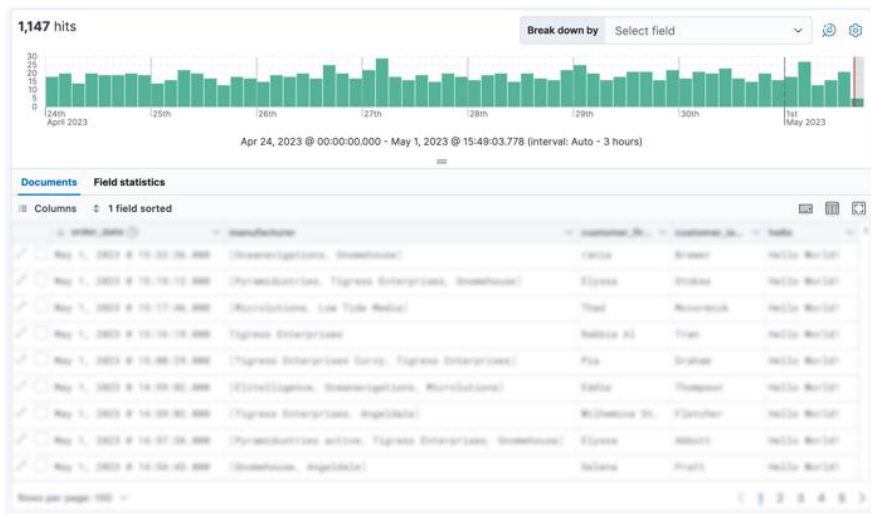


Advanced “Deception for Detection”

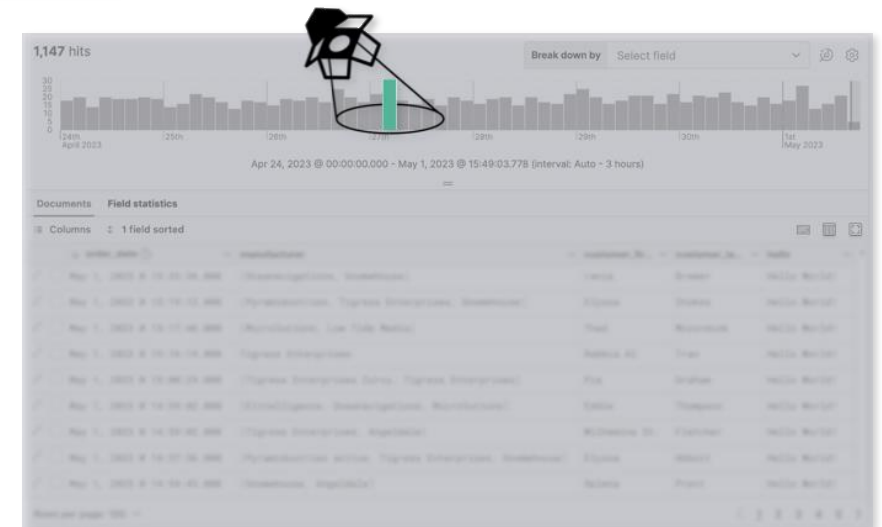
Deception technology can act as a **canary in the coalmine** when we have known weaknesses or risks we cannot remediate in the near term...



Example: Sprinkle deceptive assets on the desktop of your senior leaders or employees that repeatedly fail phishing tests



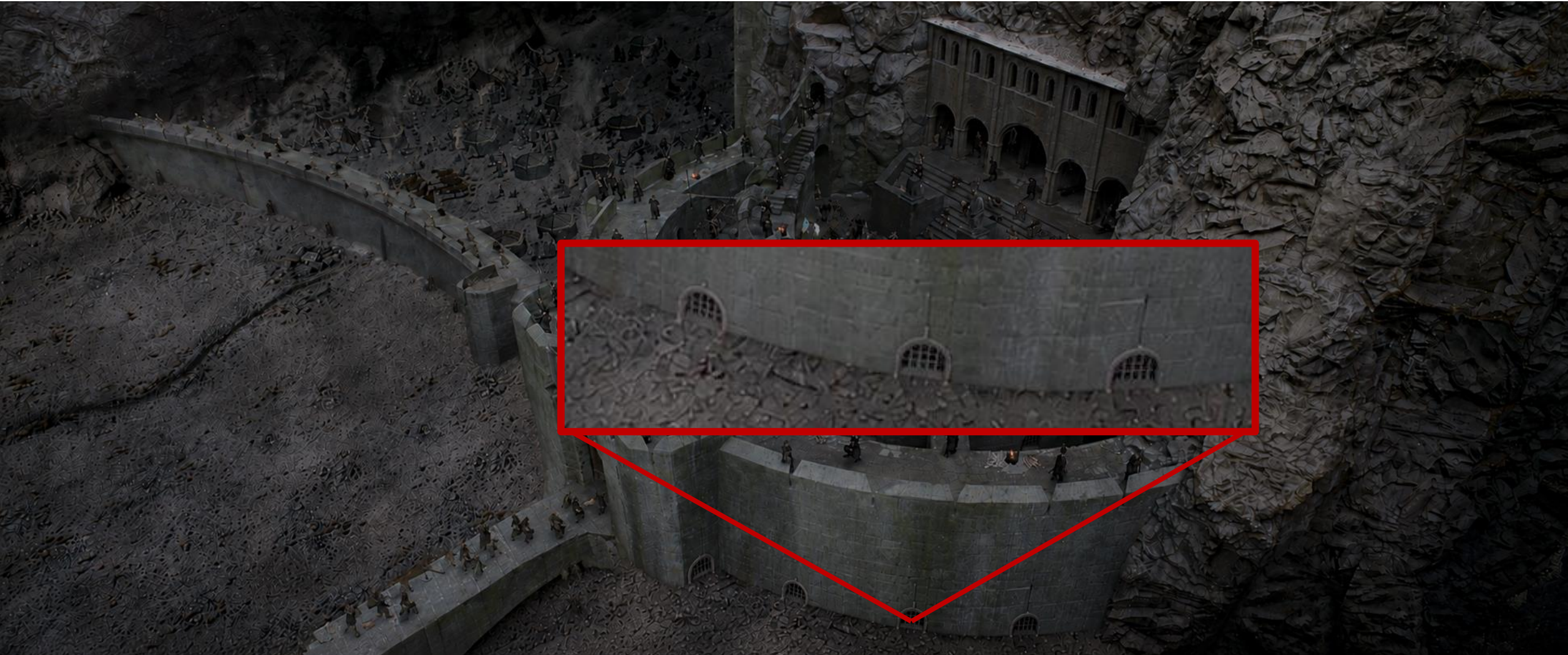
...or as lead generation mechanism with large amounts of data



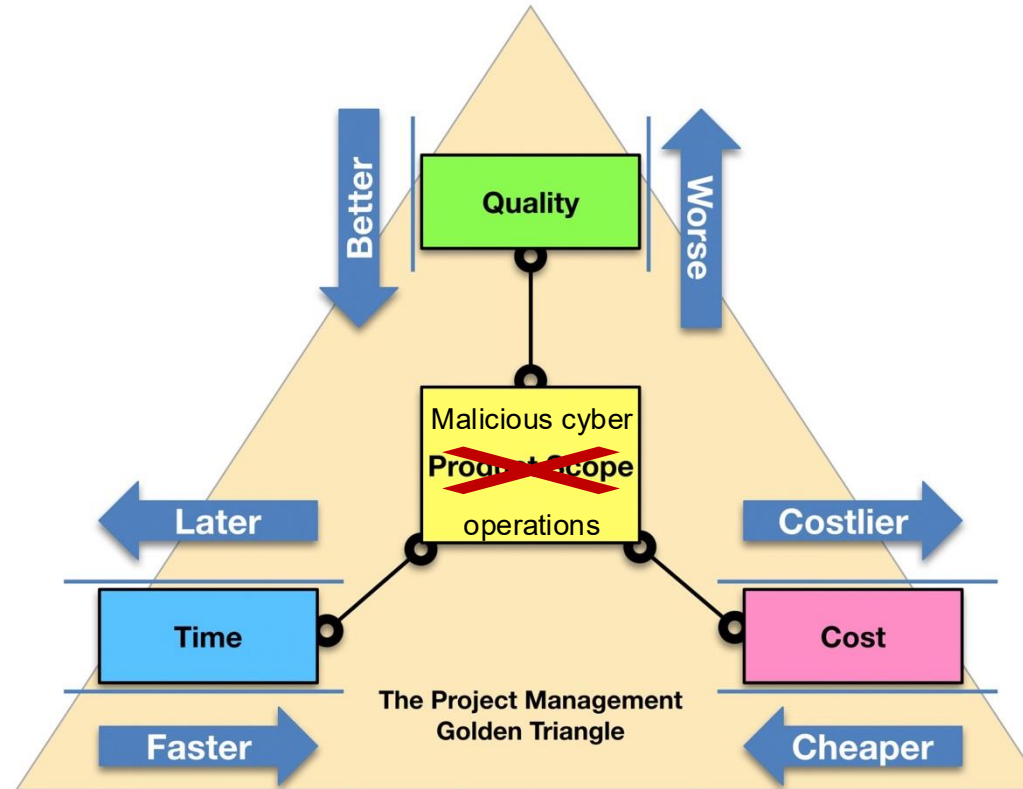
It is easy to find the weakness when there is only one.



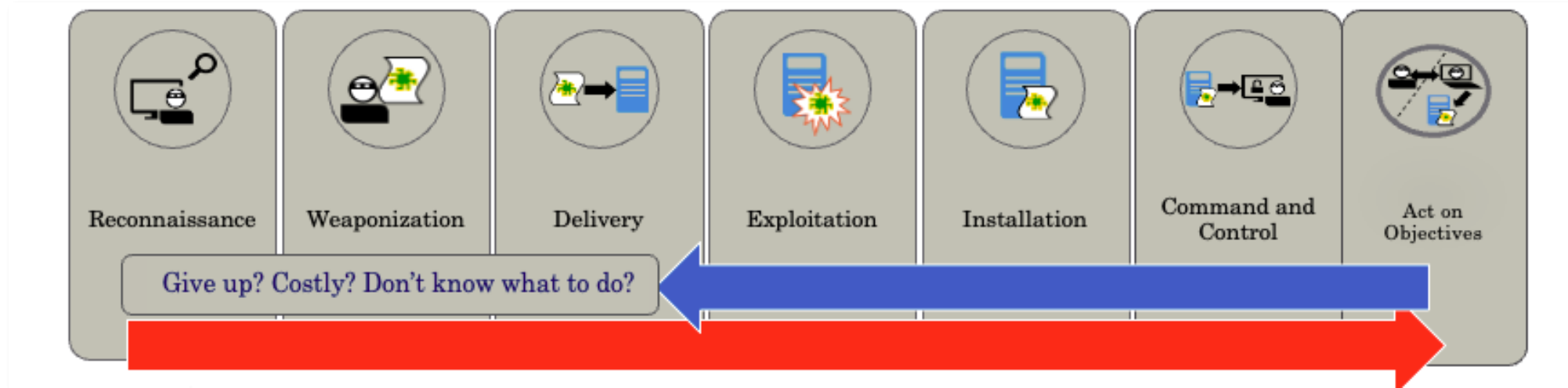
What if only ONE of these storm drains actually led into the castle, while all the others were convincing decoys?



Start to think about “Affecting” Operations



Traditional Defense is Reactive



Most defensive postures implicitly accept a disadvantage.

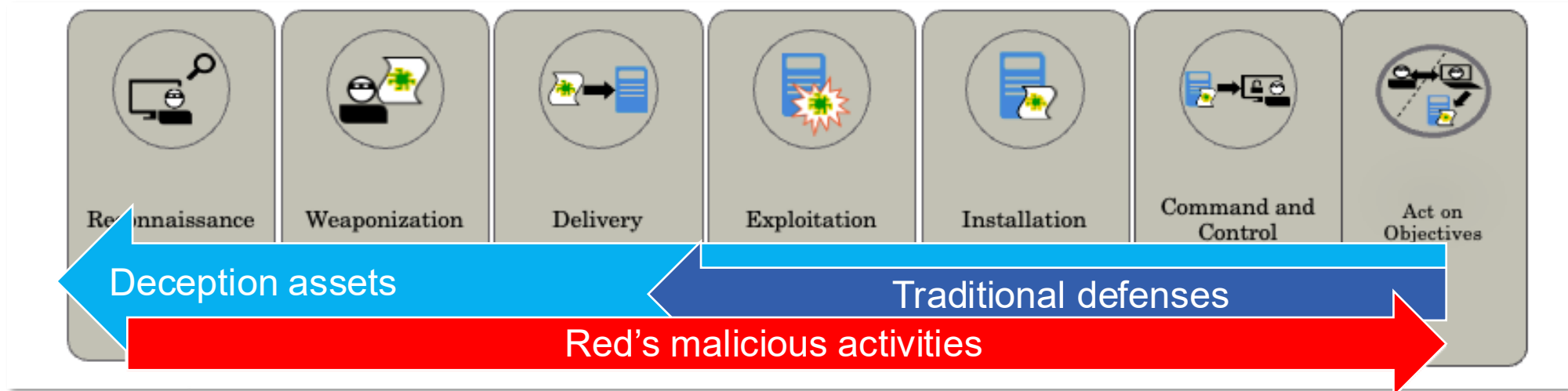
During reconnaissance and weaponization, the **adversary operates freely and accurately.**

The defender has conceded:

- **Time** (the adversary sets the pace)
- **Position** (the adversary chooses the attack surface)
- **Initiative** (the adversary dictates the engagement)

[*referencing Lockheed Martin's Cyber Kill Chain® as an attack life cycle](#)

Adversary Engagement is Proactive



Deceptive assets **disrupt this asymmetry.**

Engage the adversary through believable false signals **before they gain certainty.**

The **adversary's view becomes incomplete, inaccurate, and expensive to validate.**

We want to cause them to **make poor decisions, force re-validation/hesitation, cost them resources,** and ideally **deter them** altogether.









You
want
to
get
here.

You
are
here.



Our Dam Metaphor

- Adversaries are an endless stream
- Stop what you can
- But assume the APT will always find a way through
- Adversaries often follow path of least resistance. Therefore:
 - Make their job difficult, confusing, and slow
 - Channel away from important things
 - Give yourself every opportunity to find them
 - Observe their actions to better detect them



Briefing Flow

What is Adversary Engagement
and Why Does it Matter?

01

How Do We Advance Beyond
“Deception for Detection”?

02

**How Are We Working to Enable
Advanced Adversary Engagement at
Scale?**

03

An open-source framework, AXOLOTL, to
explore adversary engagement in your
environment today

04

Barriers to Advanced Adversary Engagement at Scale

**Requirement for Additional Commercial
Off The Shelf (COTS) Products**
Adding another technology is overwhelming



Expert Dependent

Effective deployments need technical expertise and an understanding of the threat landscape & the defender's environments

Vendor Lock-In

Heavy dependence on a single vendor's ecosystem can limit customization and adaptability.

How We Needed to Overcome These Barriers

**Requirement for Additional
COTS Products**
Leverage existing & open-source
resources



Expert Dependent
Use AI & mapping to
ATT&CK® to lower this
expert dependency.

Vendor Lock-In
Offer flexible, modular
solutions intended to work
alongside common tools

Living off Your Land Engagement (LOTLE)

Reusing existing assets, data, and forensic artifacts as breadcrumbs, tripwires, and decoys



Living Off the Land: Turning 2025 CVEs Into Active Defense Opportunities



Owen Sutter ., DSc. ✓
Specialist in Cybersecurity Strategy and Innovation



April 29, 2025

Introduction

As threat actors increasingly exploit emerging vulnerabilities, defenders have an opportunity to shift from reactive defense to intentional engagement. One powerful strategy is **living off the land cyber-deception** — using existing technologies to embed deceptive artifacts into an enterprise infrastructure to mislead and monitor adversaries without deploying standalone honeypots.

Rather than deploying exotic, high-friction traps, this approach builds deception into familiar technologies already present in the environment. By aligning deception with existing assets, organizations can engage adversaries earlier and gather valuable intelligence with minimal operational risk.

Opportunities and Challenges with LOTLE

Opportunities

- No new technology.
- Deploy as a stand-alone solution or to fill gaps alongside existing products.
- Harder to detect or signature.
- Tailor deployments to current maturity, environment, goals, and threats.



Challenges

- Require knowledge of assets, data, user behavior, and the threat landscape to be effective.
- Often need to write custom solutions to deploy at scale.
 - Even vendors that sell honeypot specifically provide only basic deployment resources.

Briefing Flow

What is Adversary Engagement
and Why Does it Matter?

01

How Do We Advance Beyond
“Deception for Detection”?

02

How Are We Working to Enable
Advanced Adversary Engagement at
Scale?

03

An open-source framework, **AXOLOTL**, to
explore adversary engagement in your
environment today

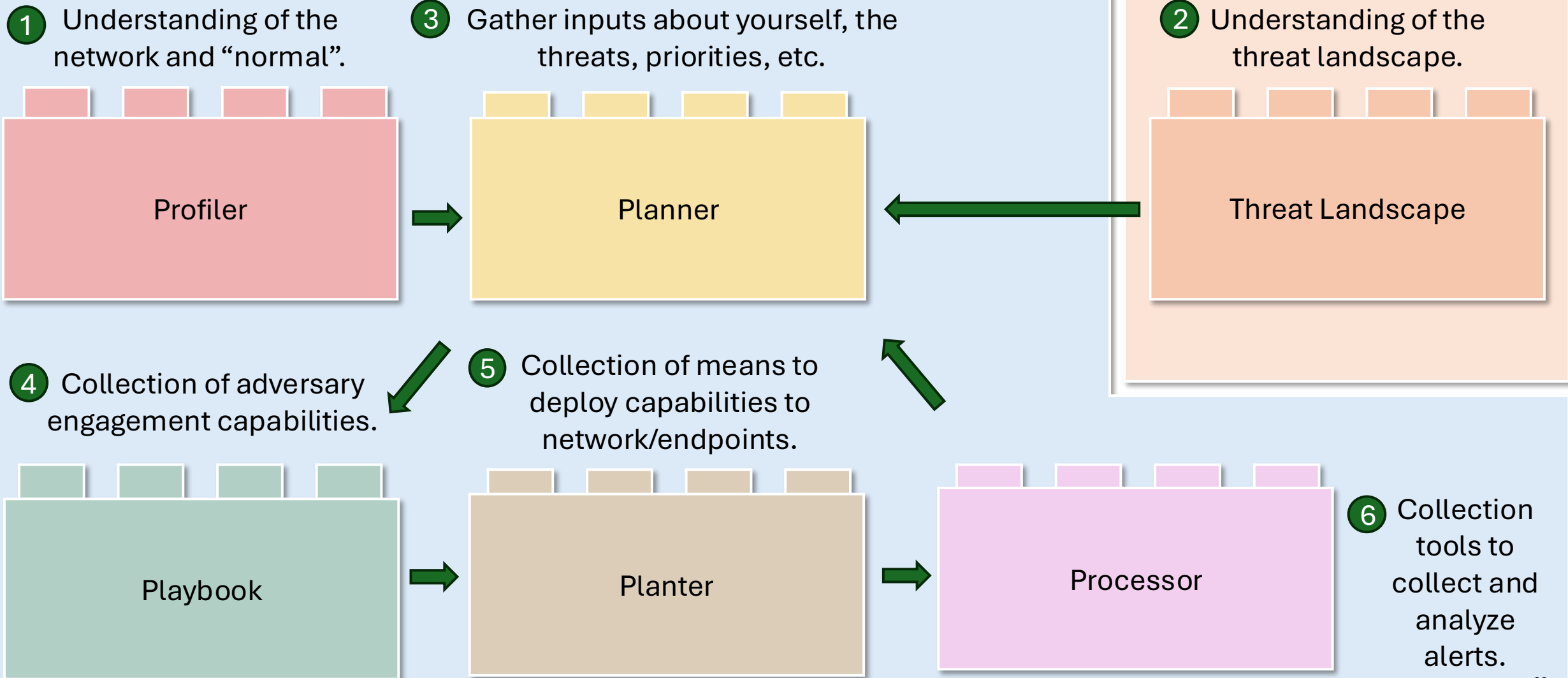
04



High Level Architecture



Defender Controlled



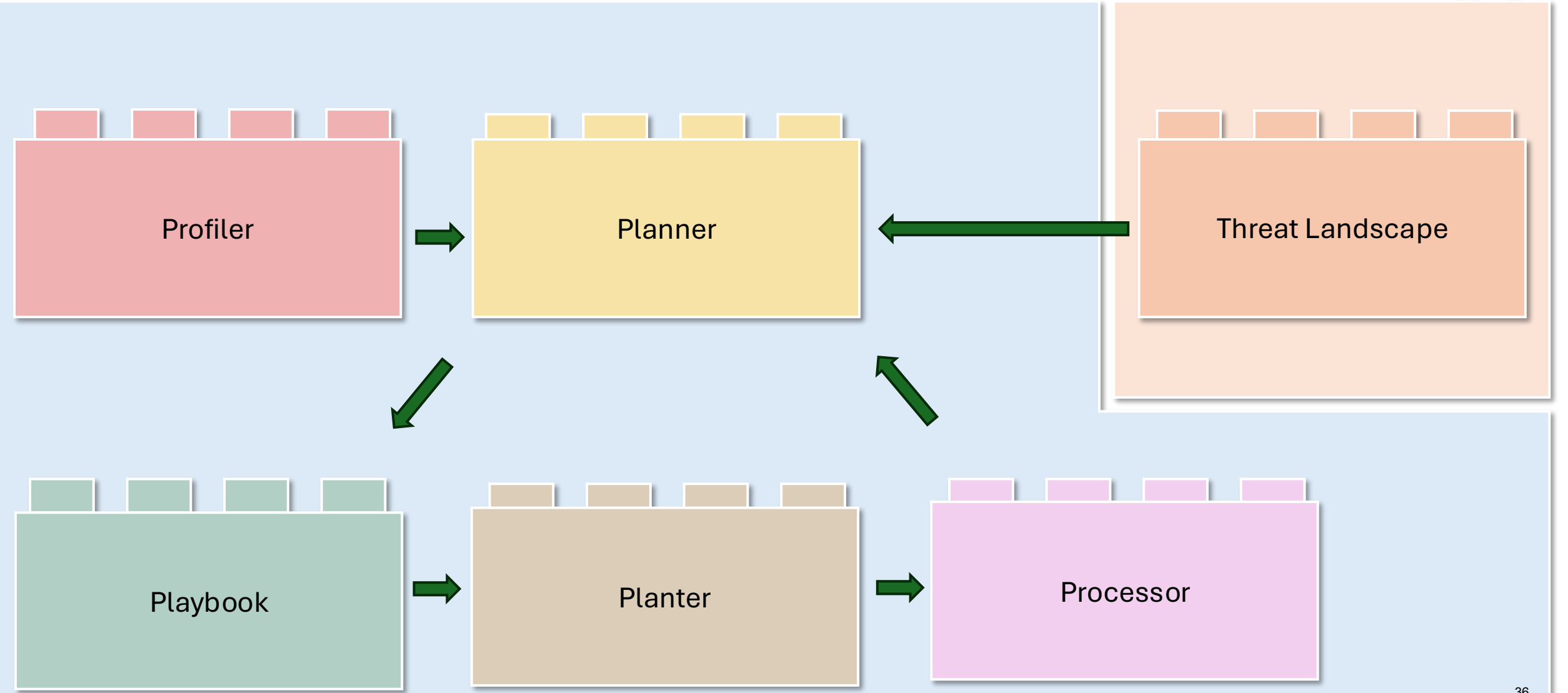
Proof-of-Concept

**Adversary eXposure and Obviation with
Living Off the Land (AXOLOTL)**

Starting with our architecture let's examine each component

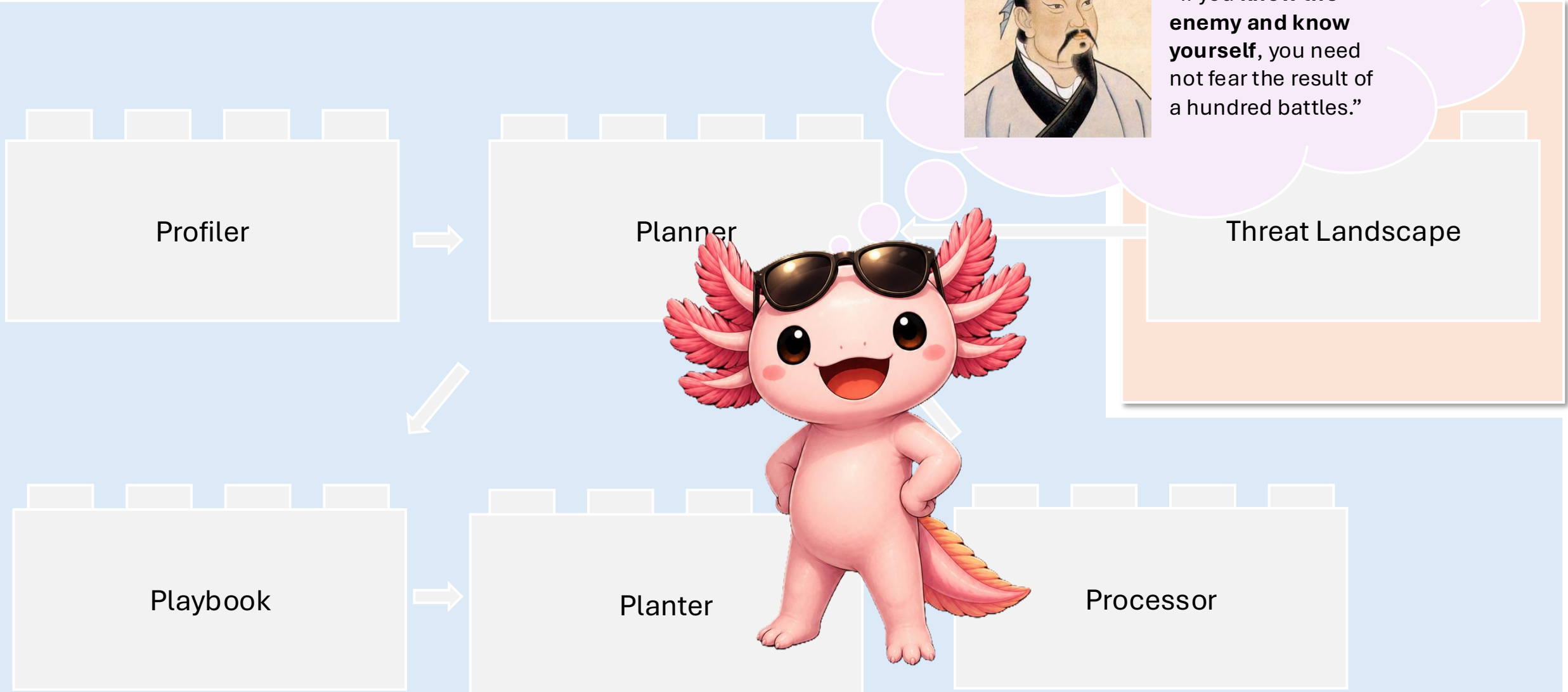


Defender Controlled



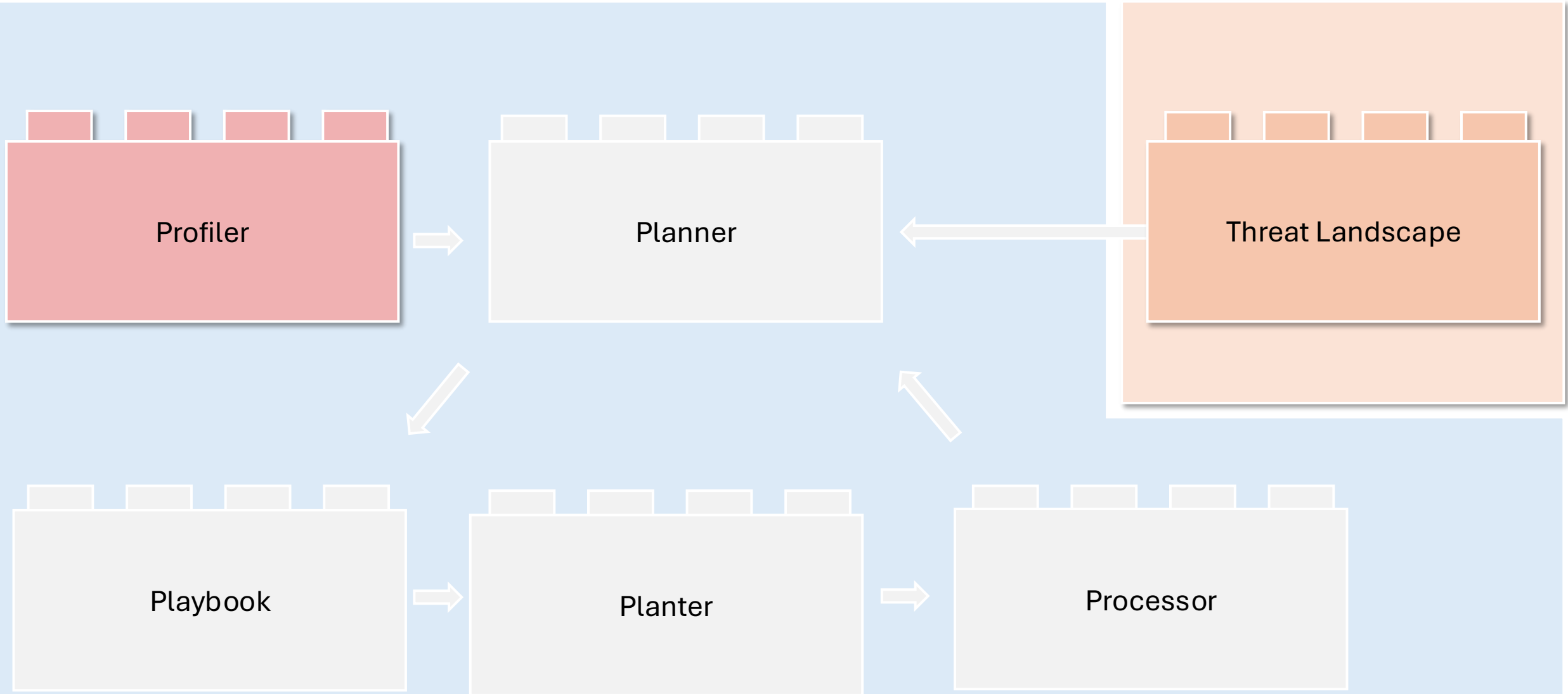
Let's get started

Defender Controlled



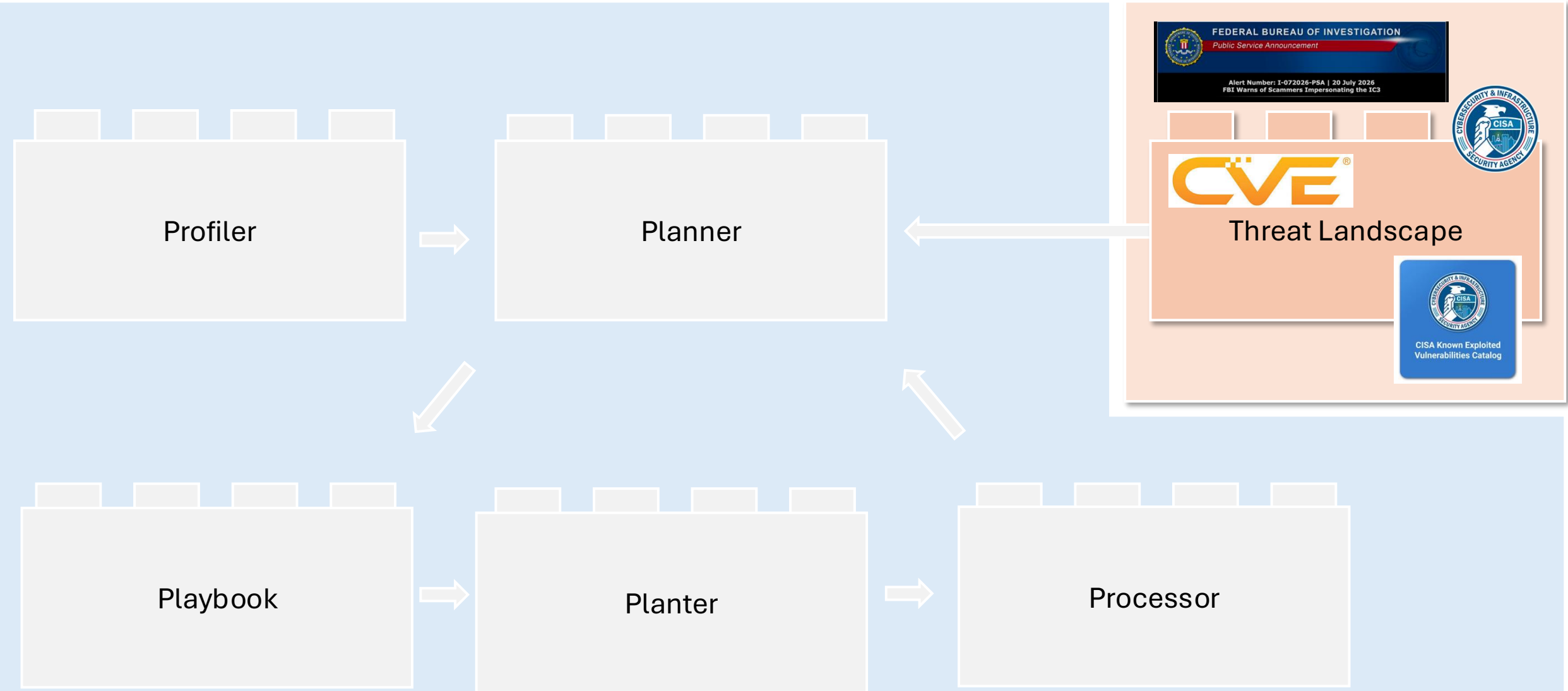
Know Yourself, Know Your Enemy

Defender Controlled



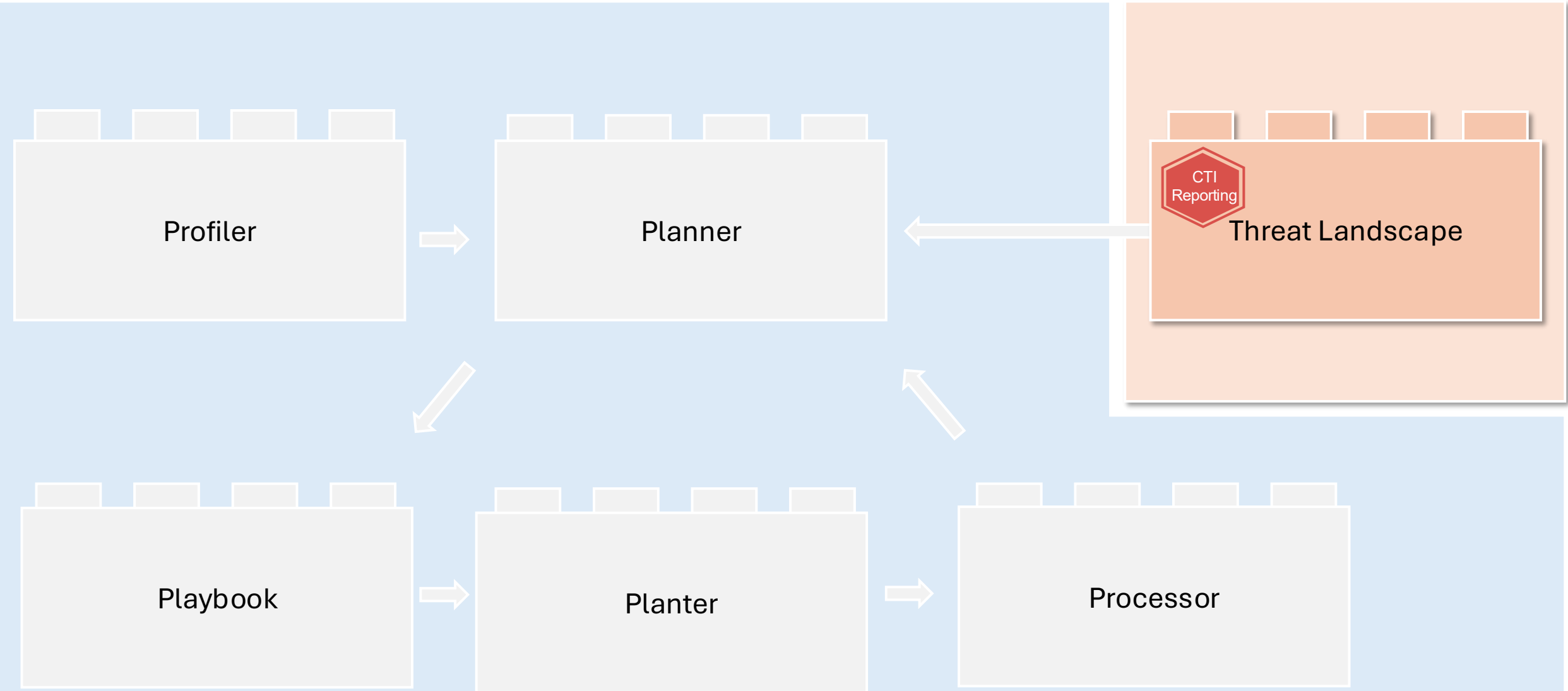
The Threat Landscape

Defender Controlled



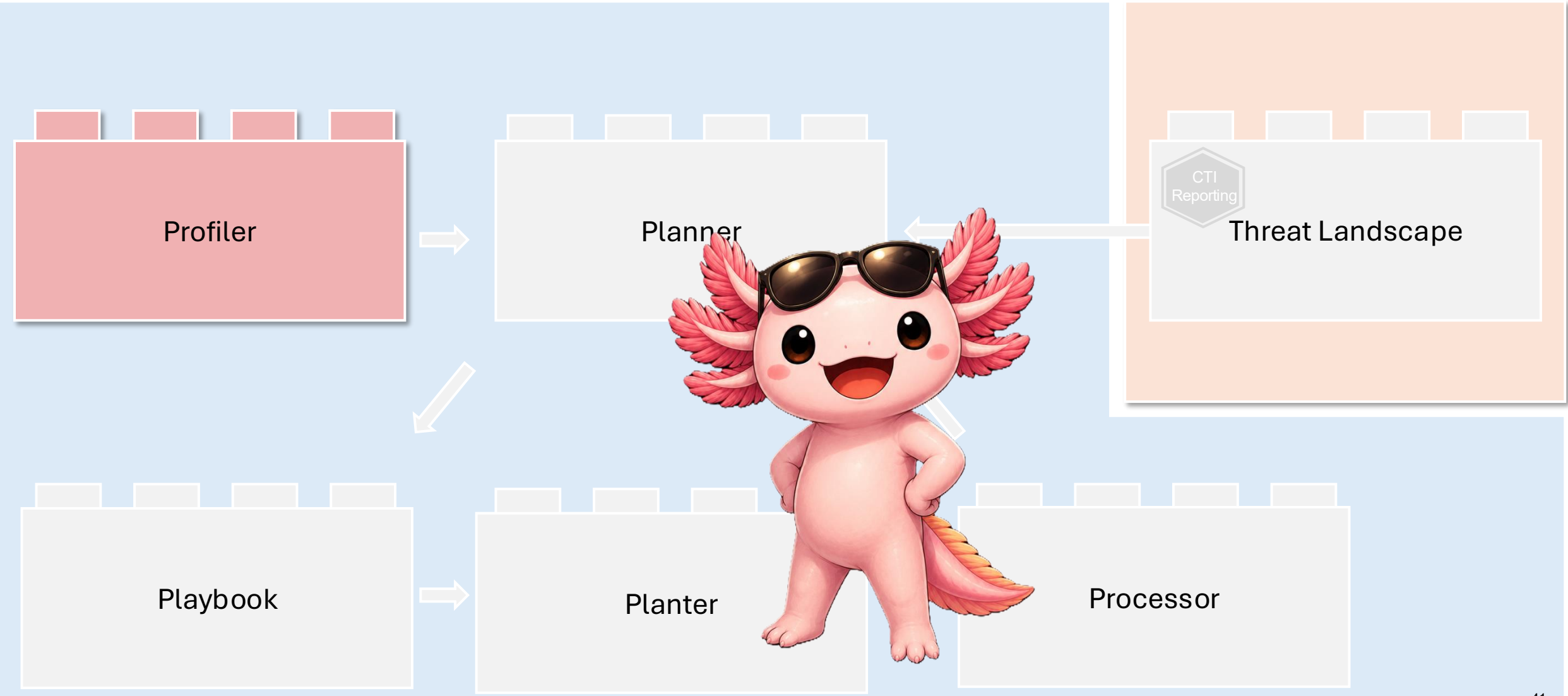
The Threat Landscape

Defender Controlled



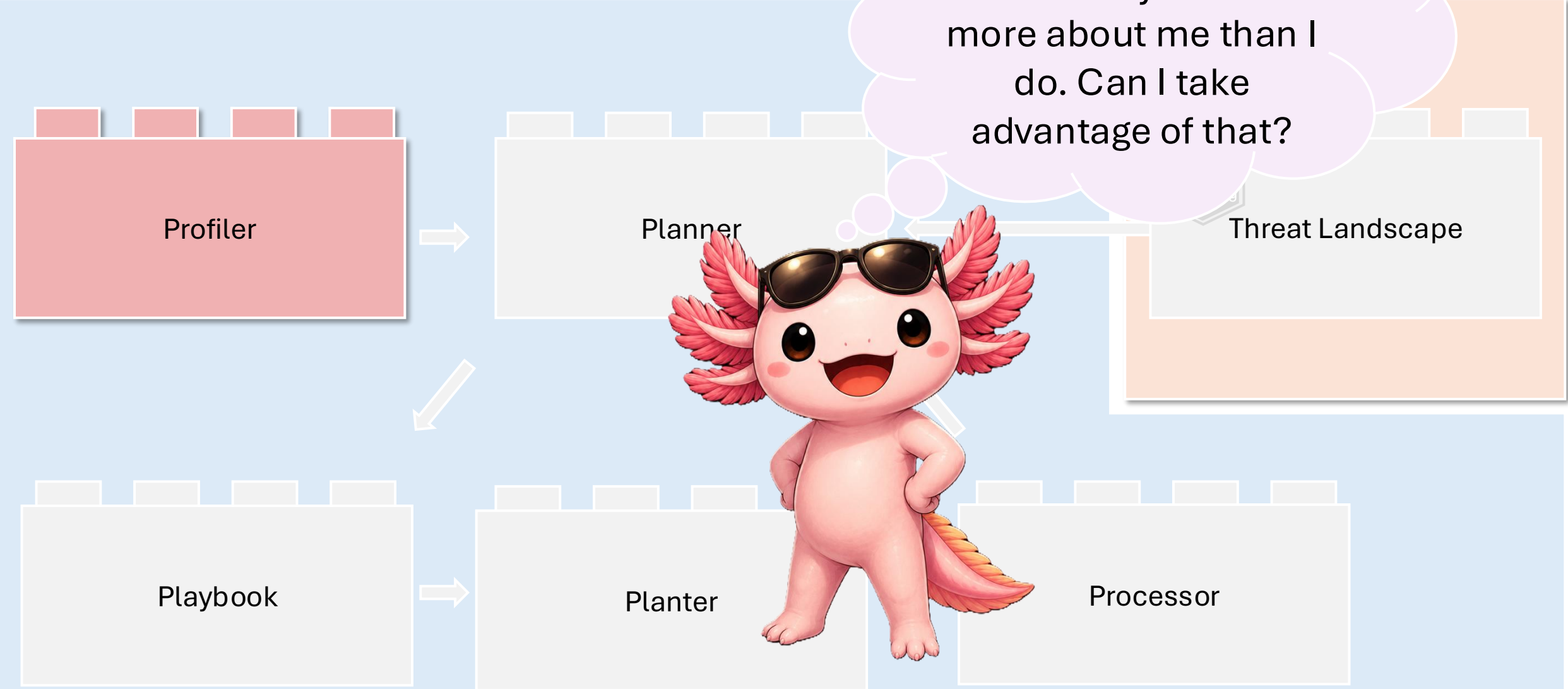
The Profiler

Defender Controlled



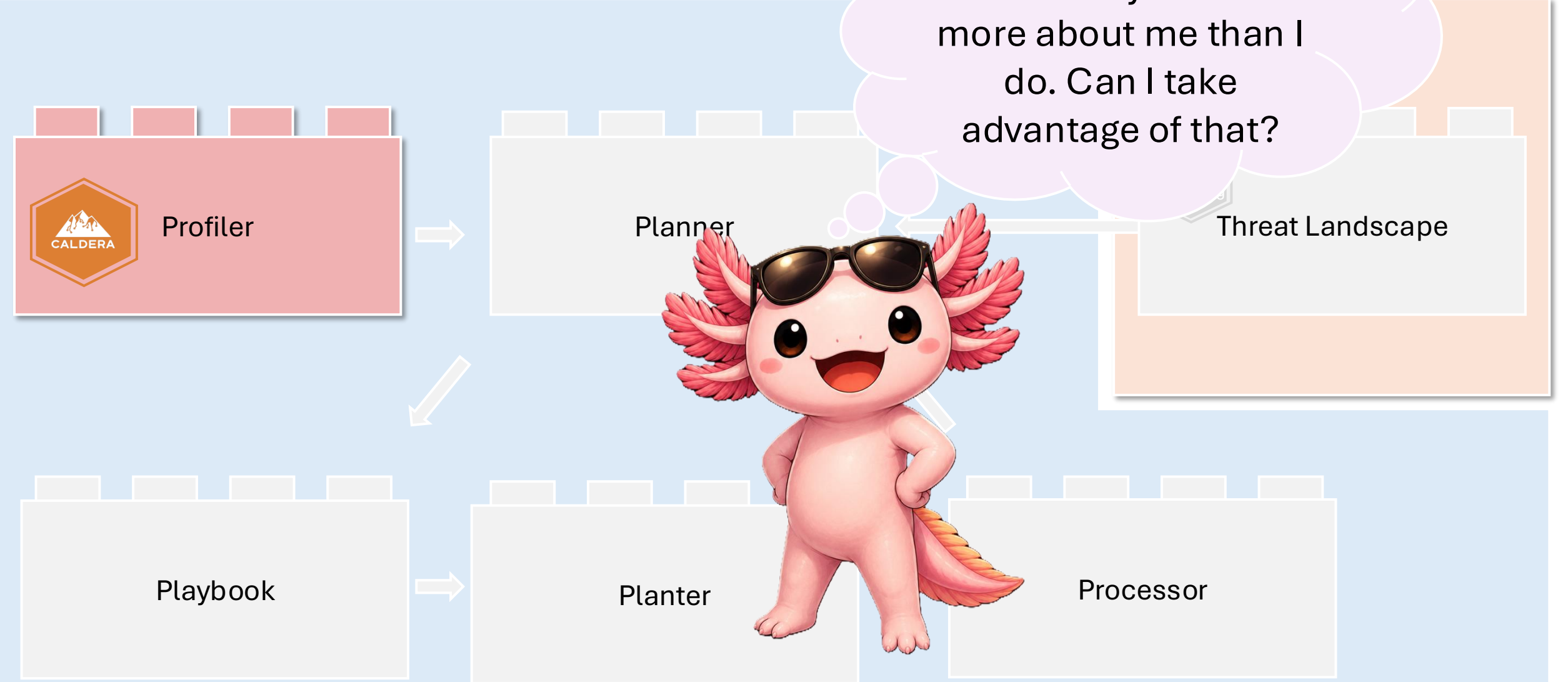
The Profiler

Defender Controlled



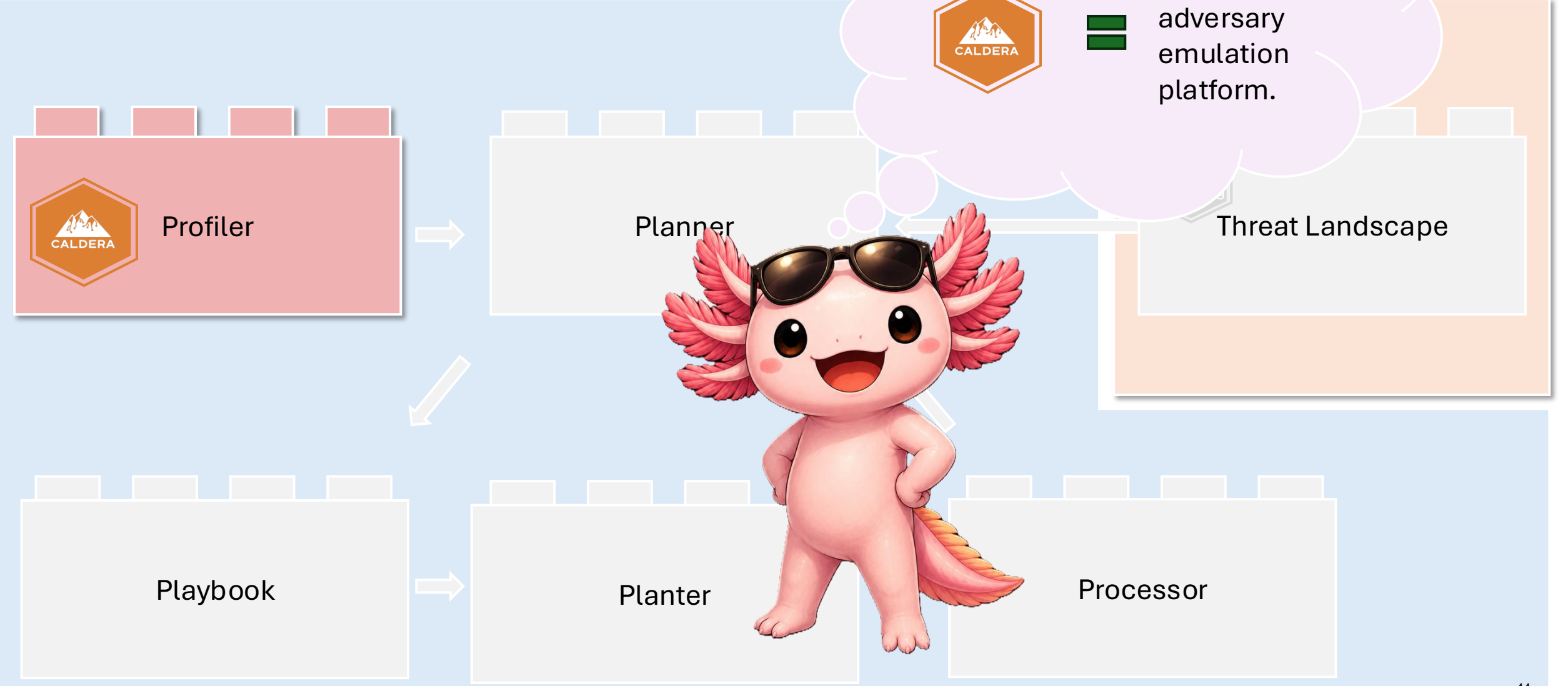
The Profiler

Defender Controlled



The Profiler

Defender Controlled



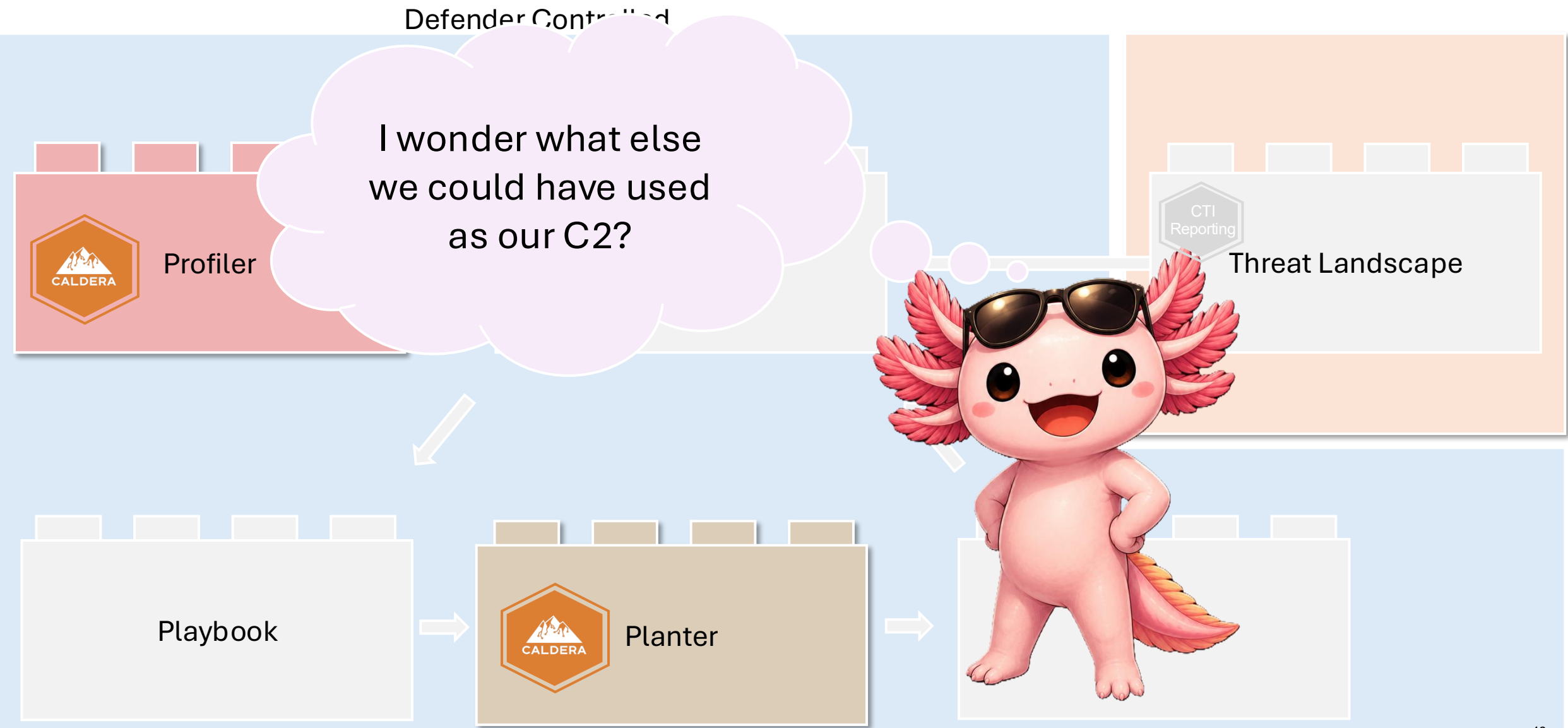
The Planter

Defender Controlled

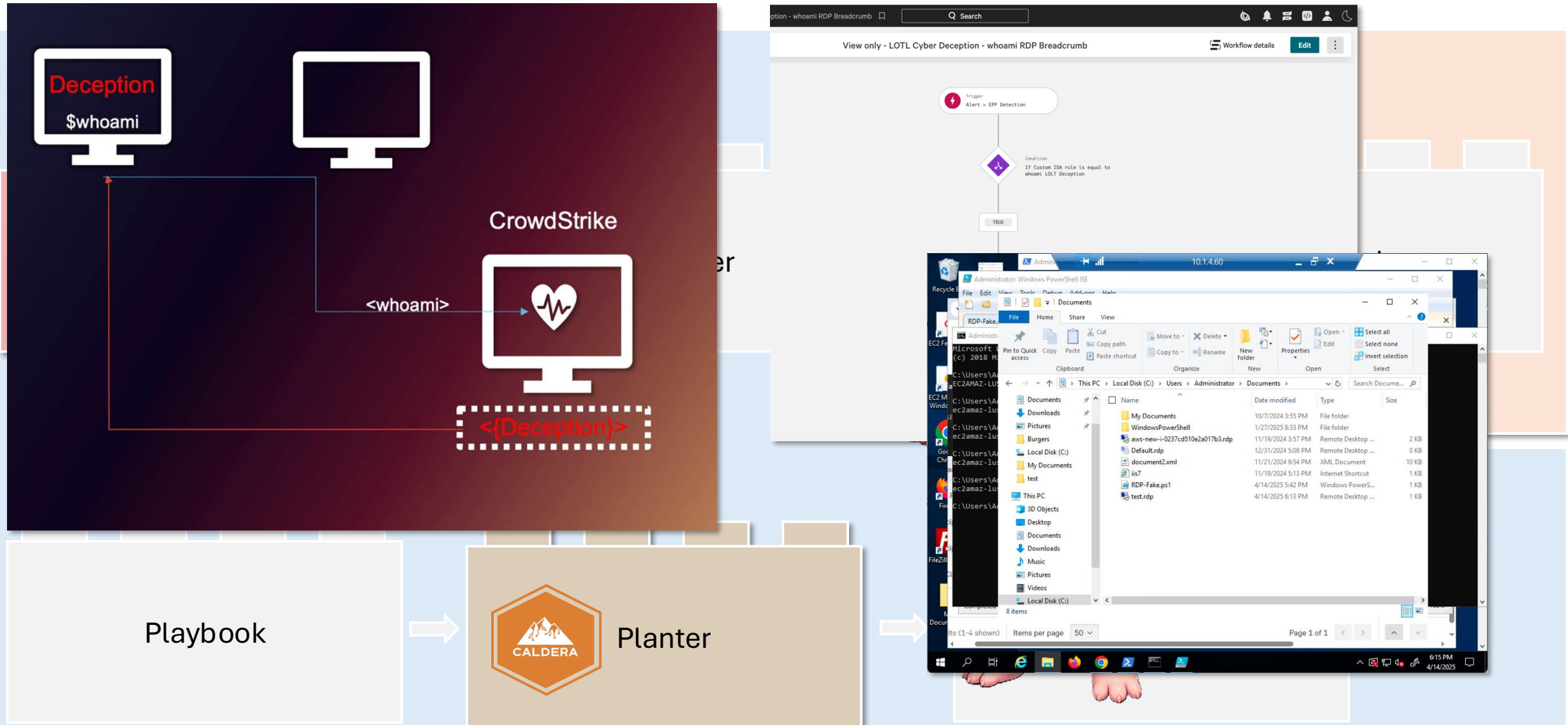
And since Caldera is essentially a C2 can I reuse it?



The Planter

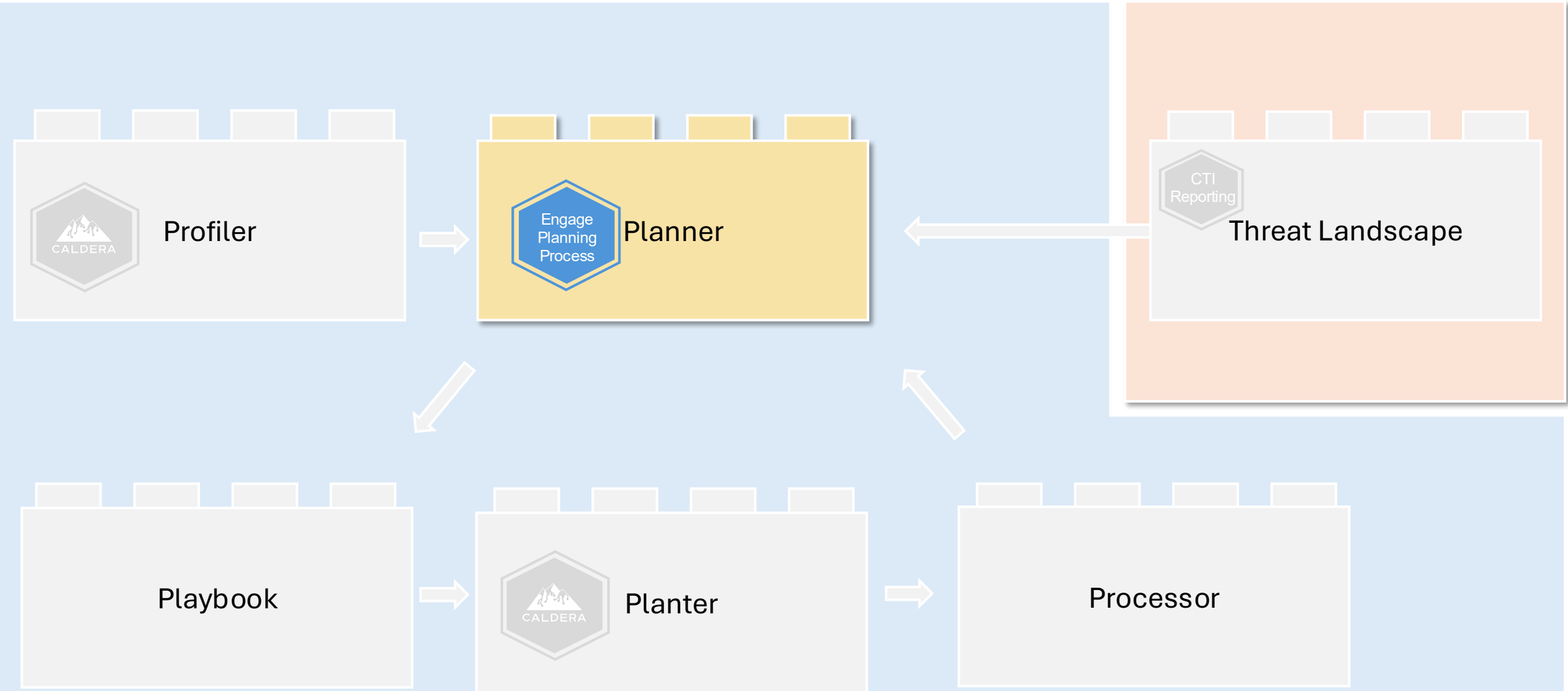


CrowdStrike (or any EDR) can also act as a planter



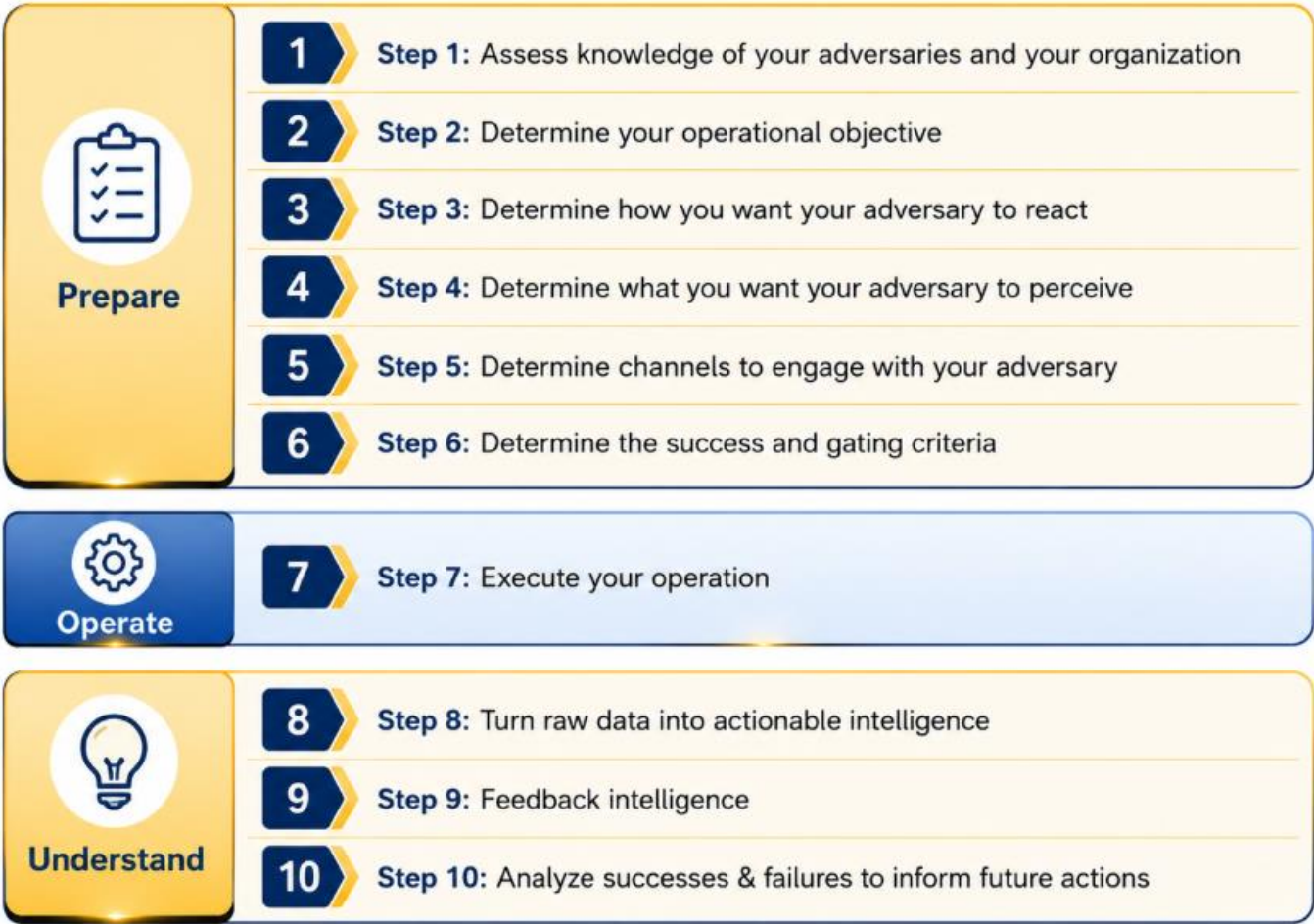
The Planner

Defender Controlled



The Planner

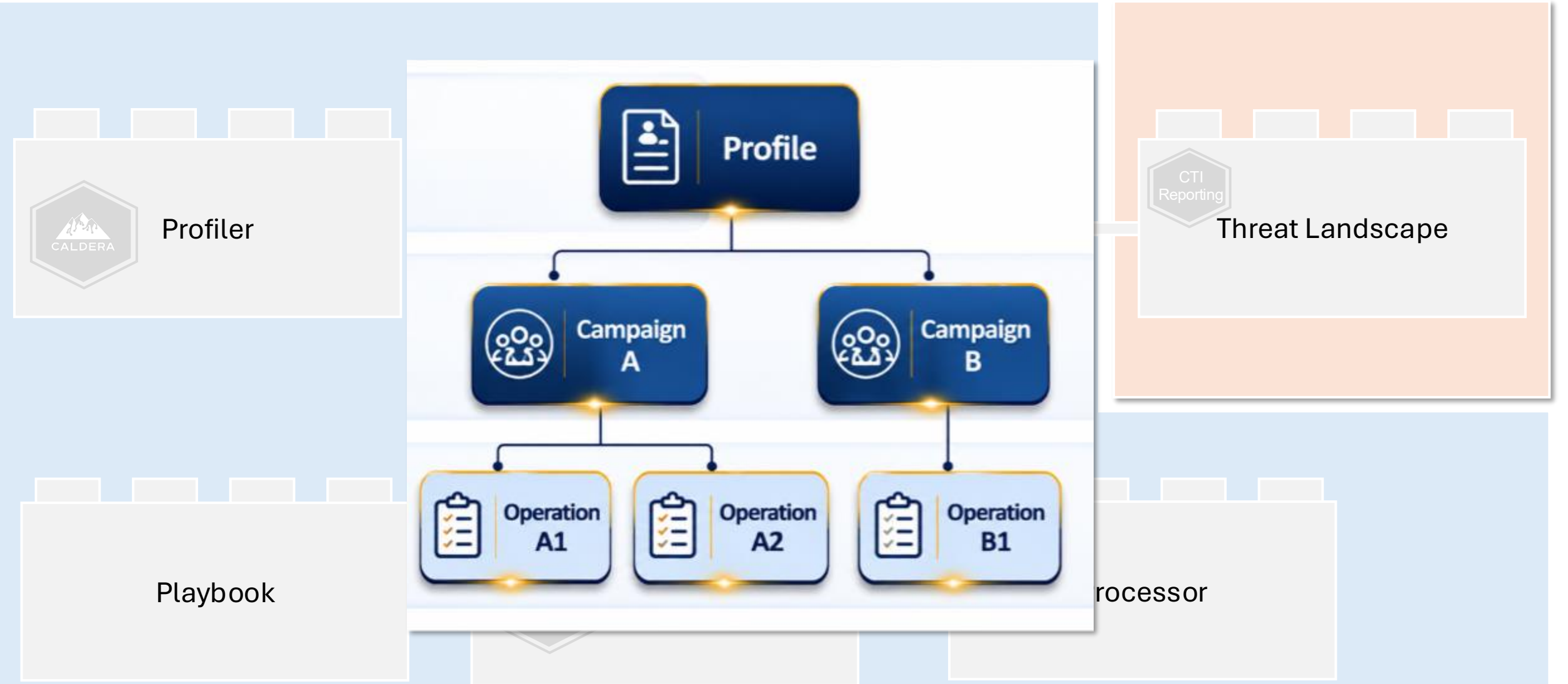
Defender Controlled



Threat Landscape

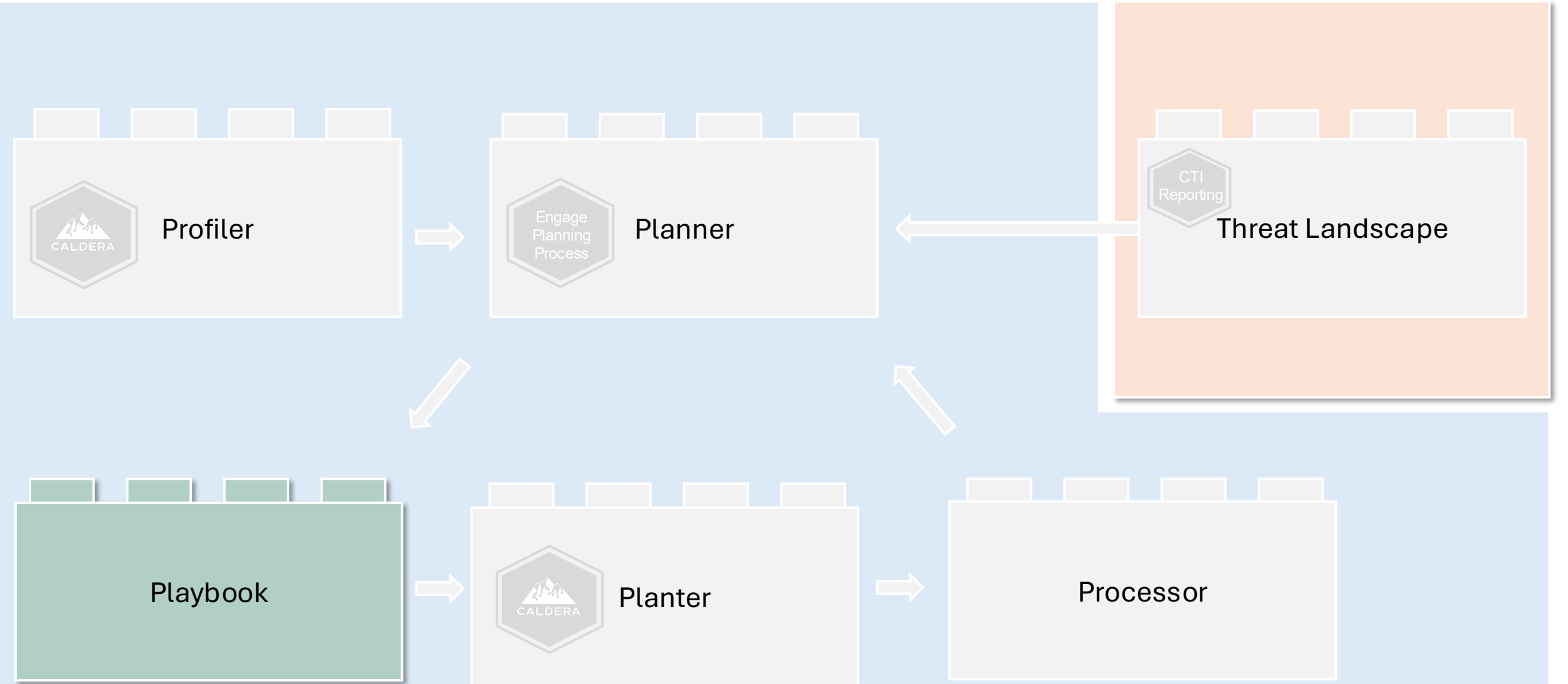
The Planner

Defender Controlled



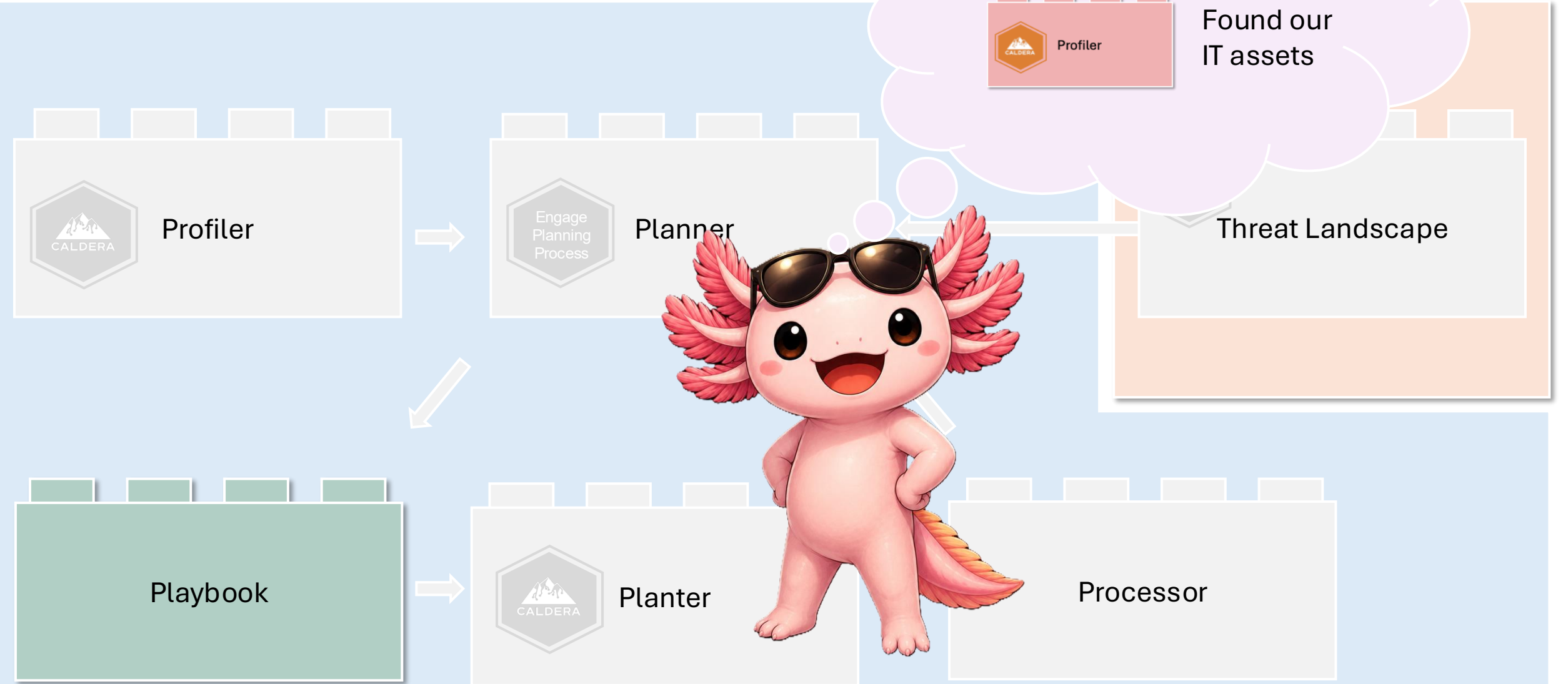
The Playbook

Defender Controlled

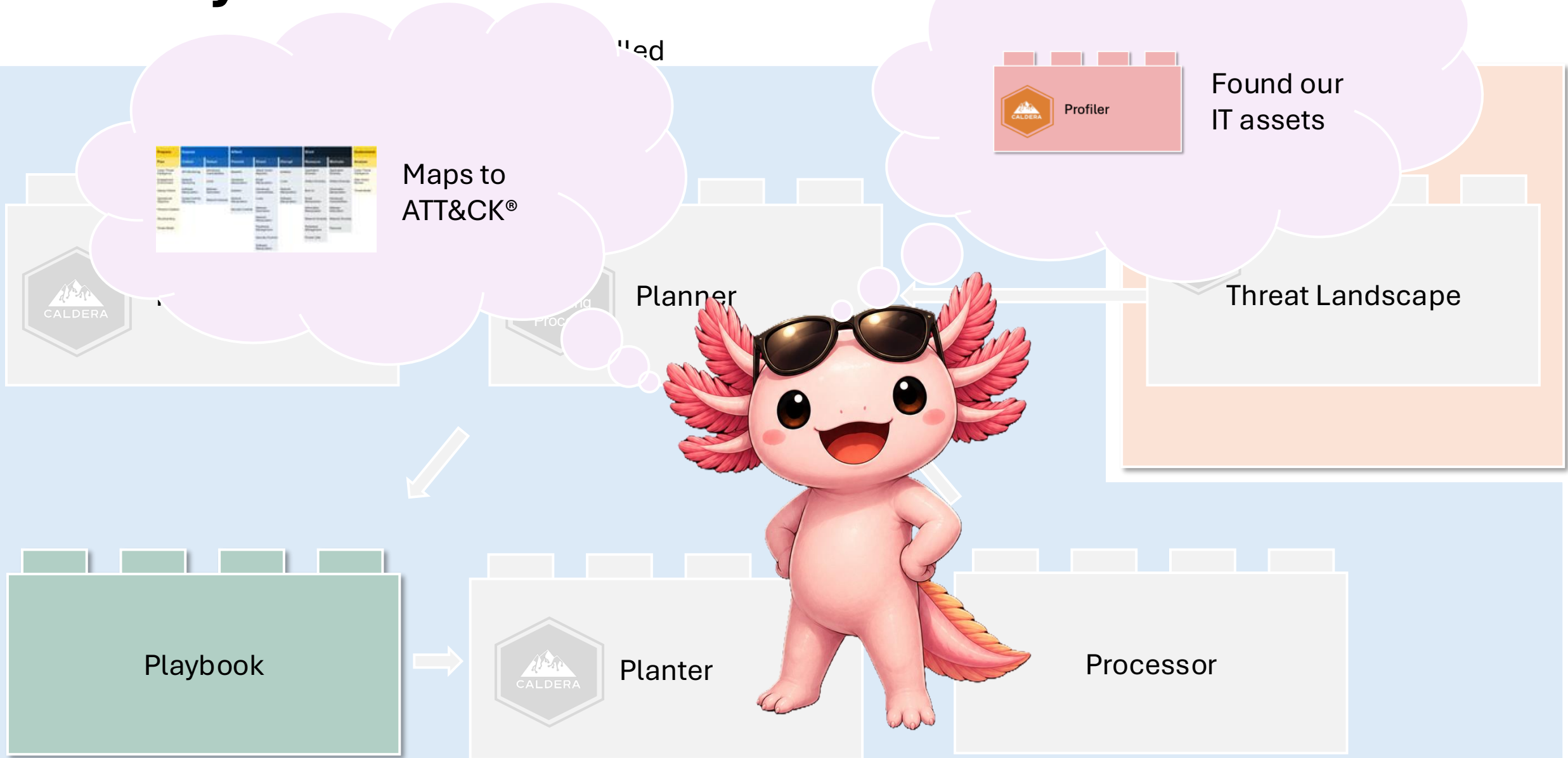


The Playbook

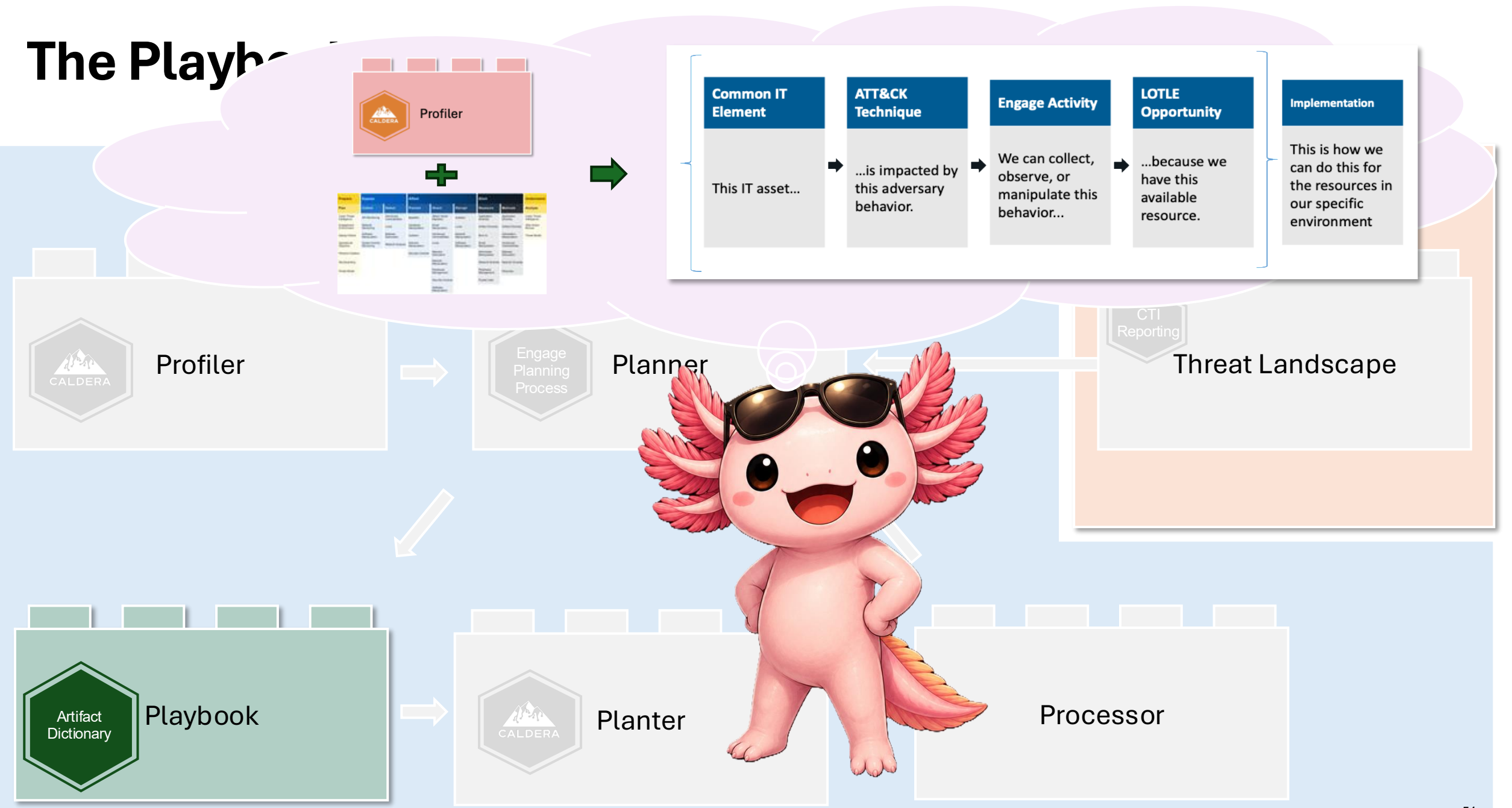
Defender Controlled



The Playbook

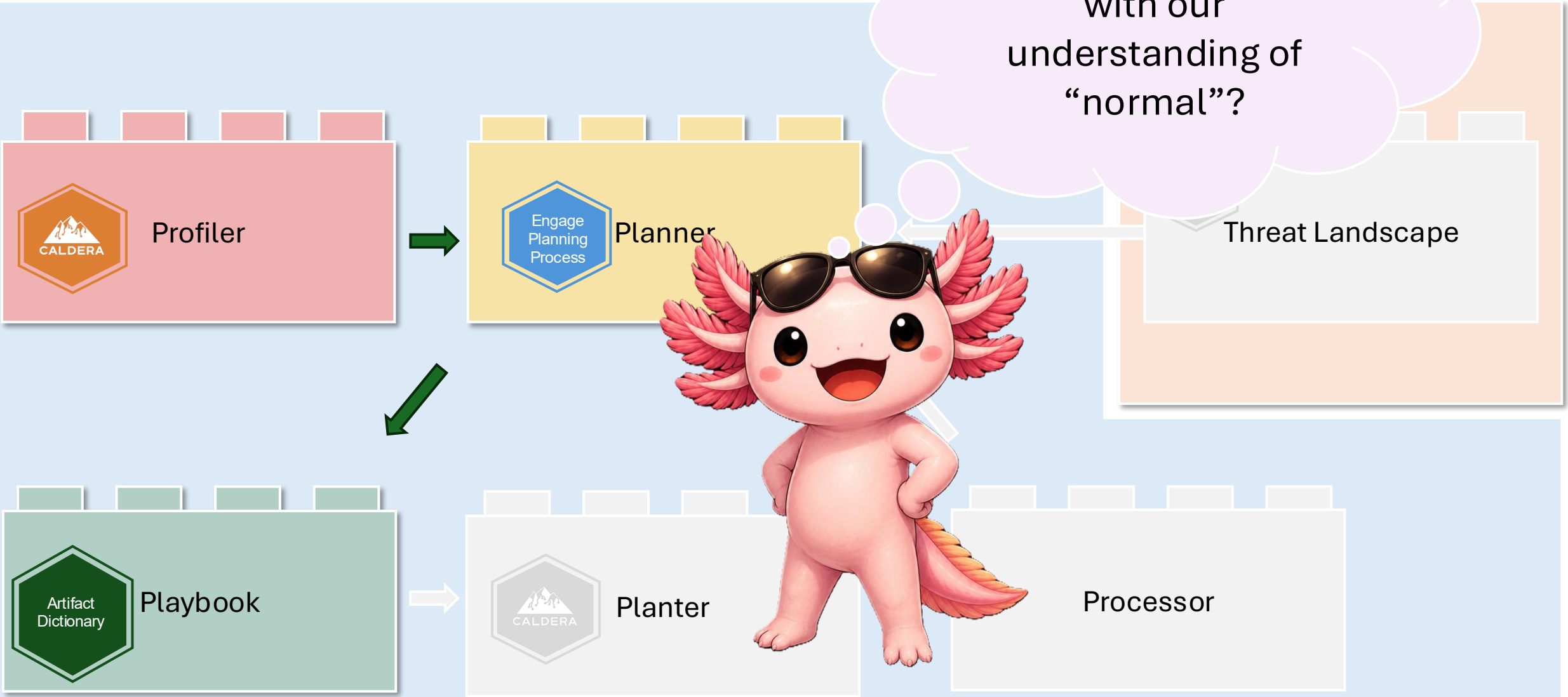


The Playbook

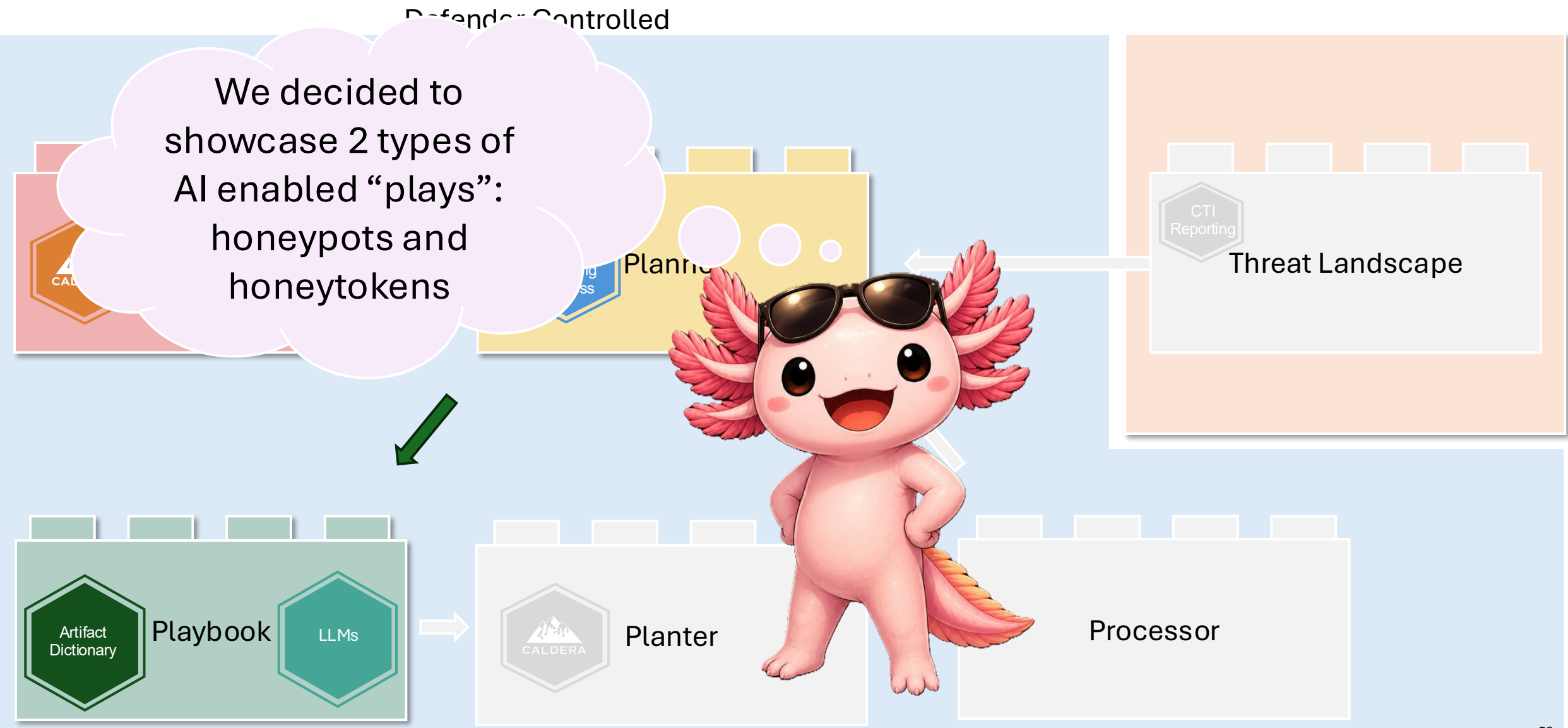


The Plays

Defender Controlled

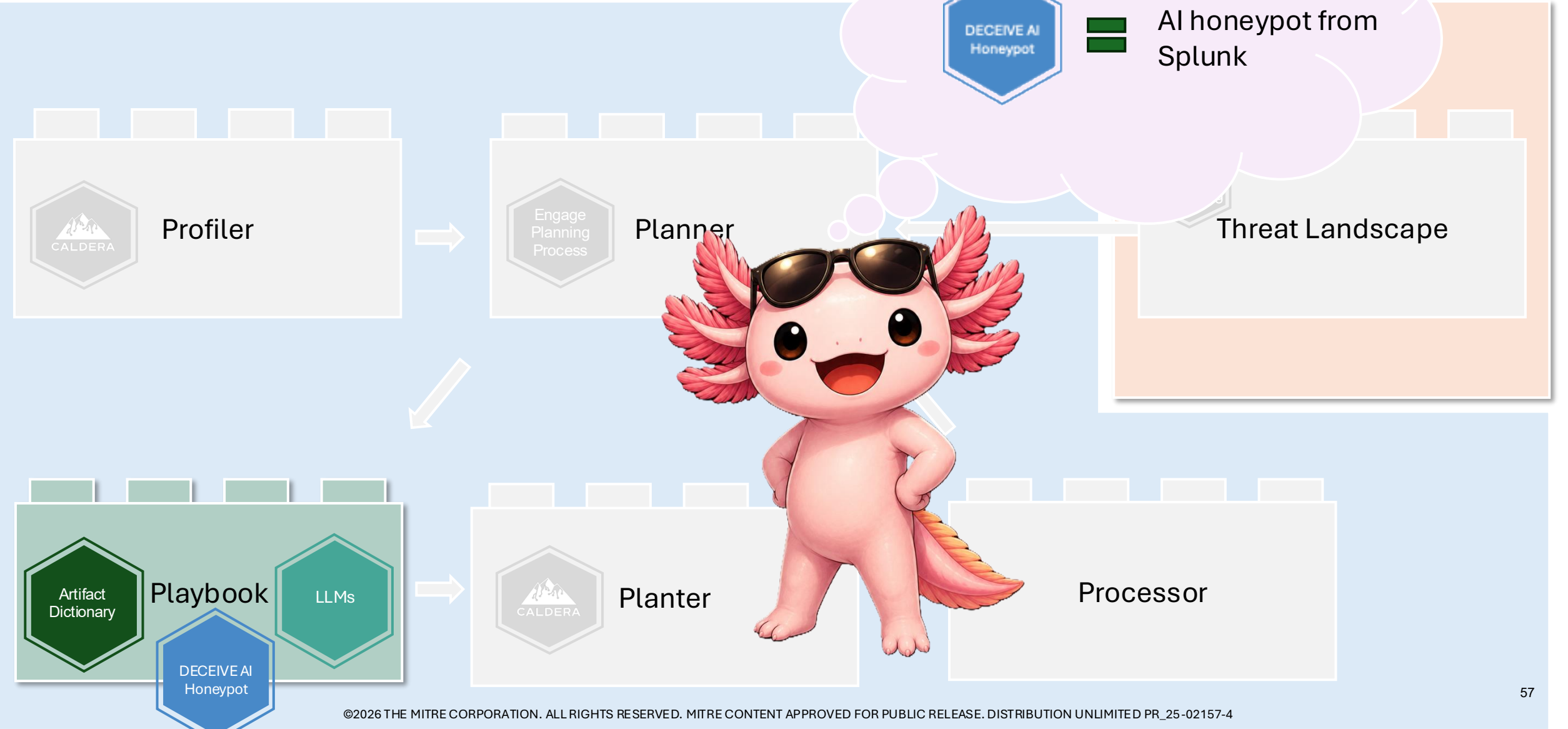


The Plays

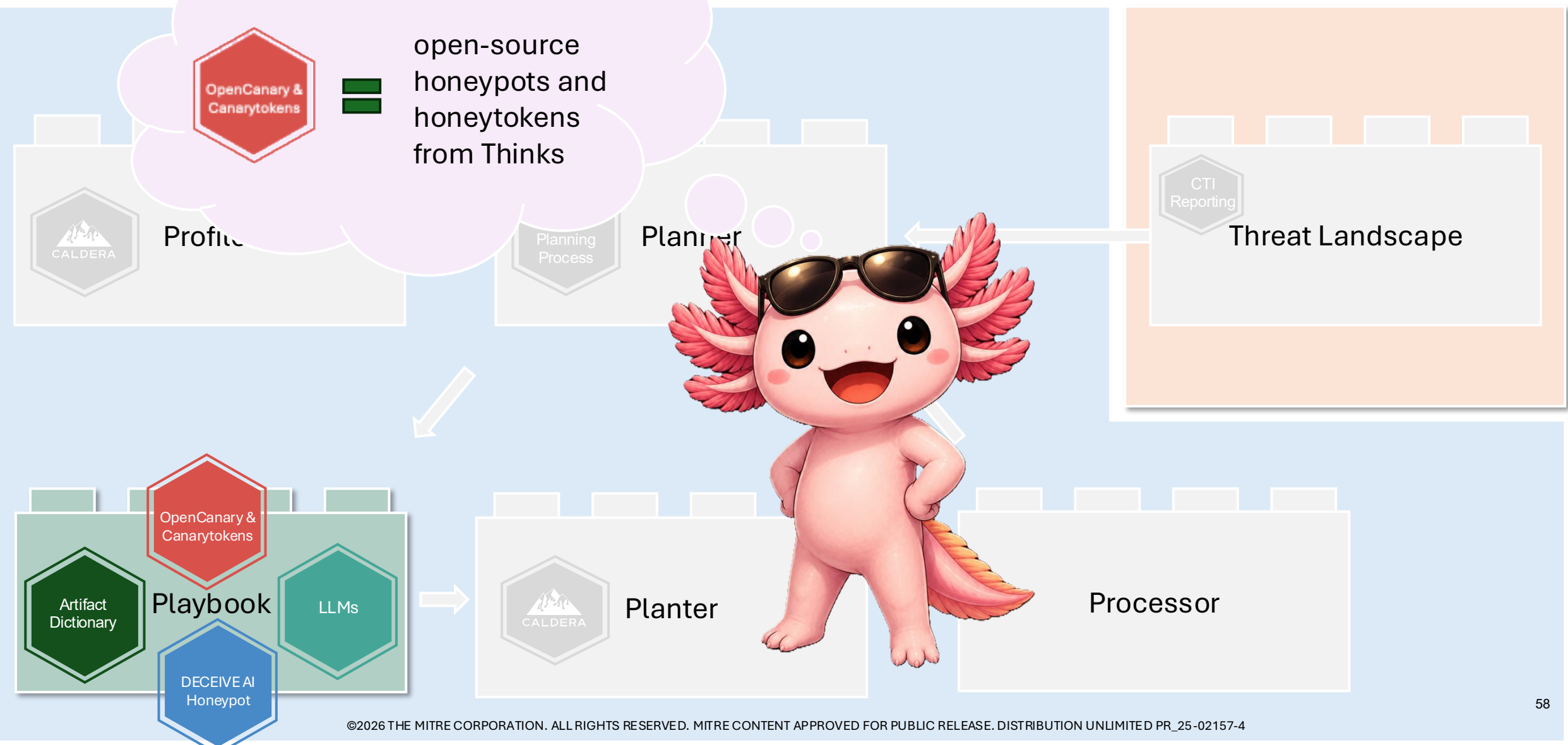


The Plays

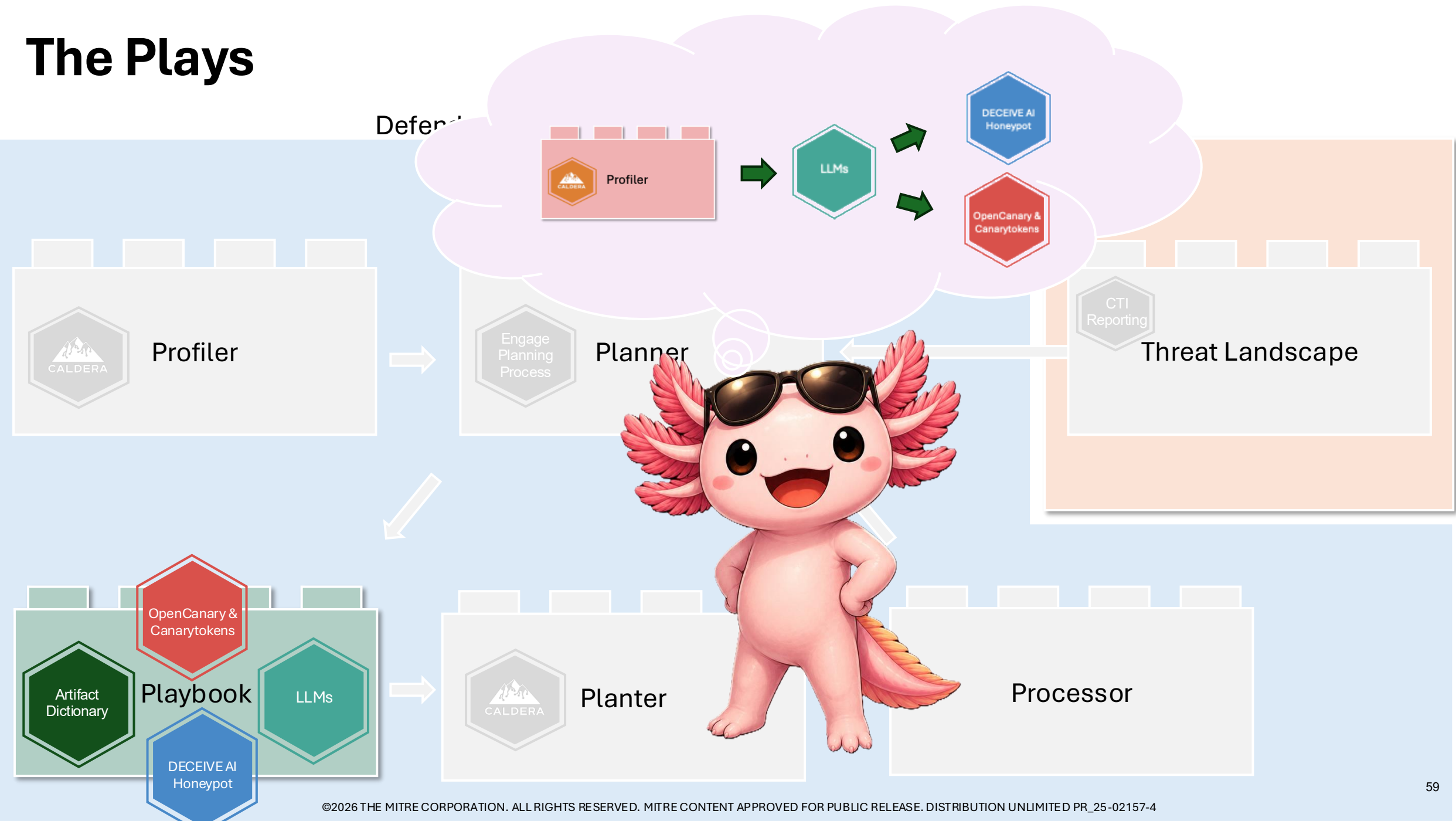
Defender Controlled



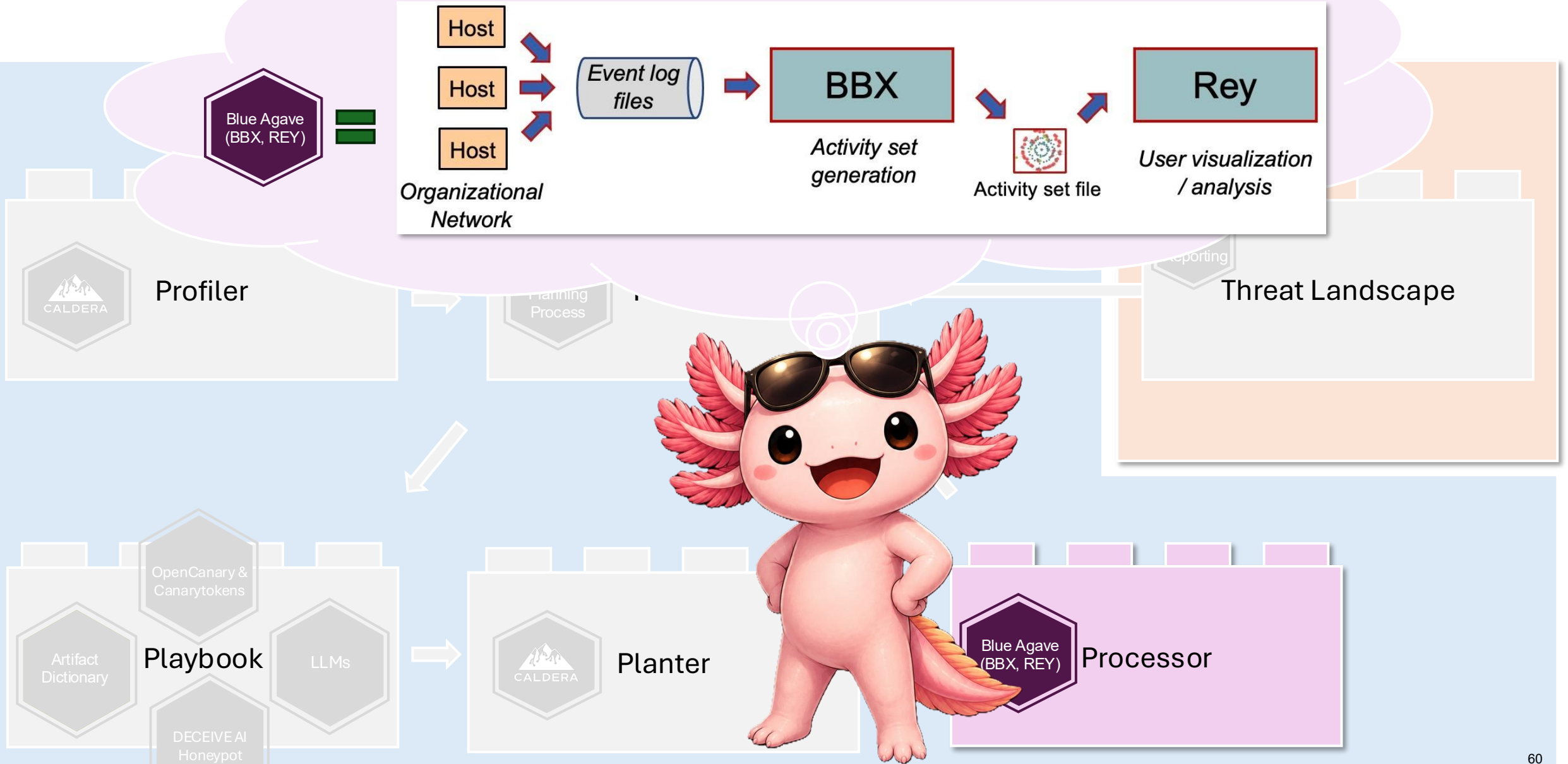
The Plays



The Plays

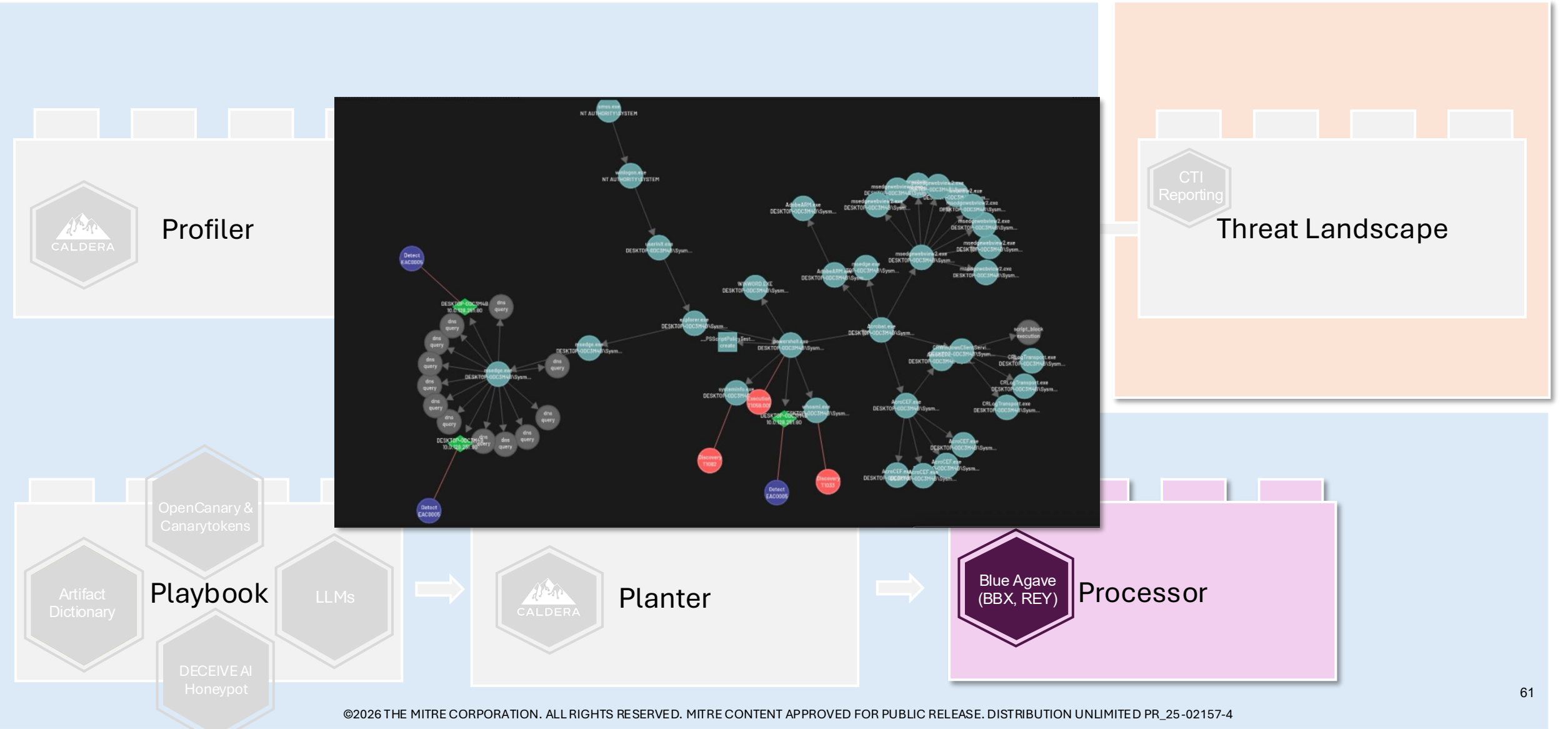


The Process



The Processor

Defender Controlled



Use activity sets to visualize alerts



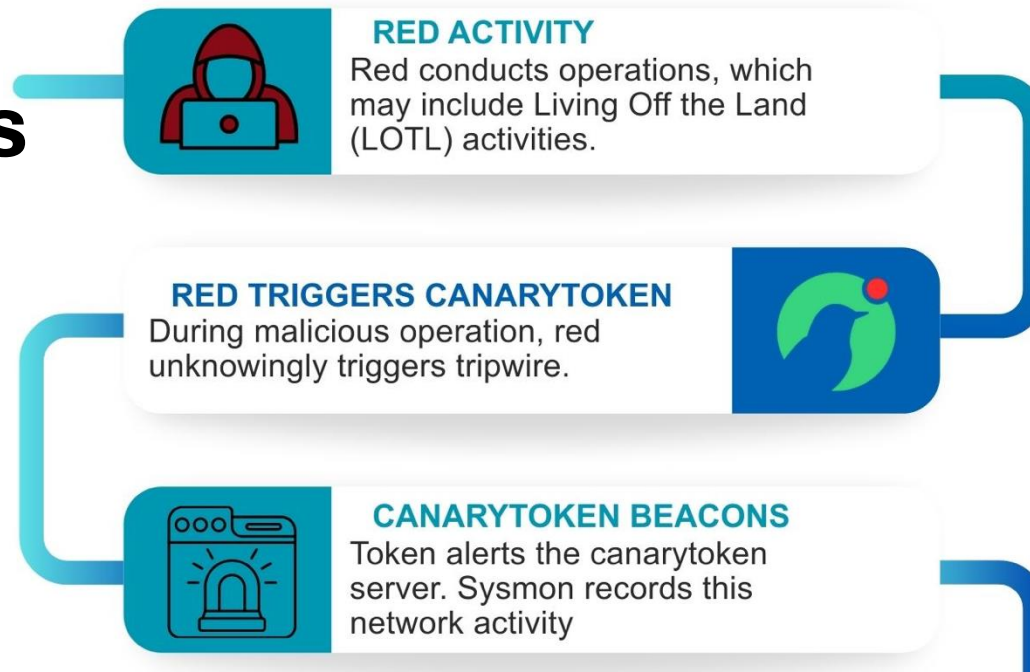
RED ACTIVITY

Red conducts operations, which may include Living Off the Land (LOTL) activities.

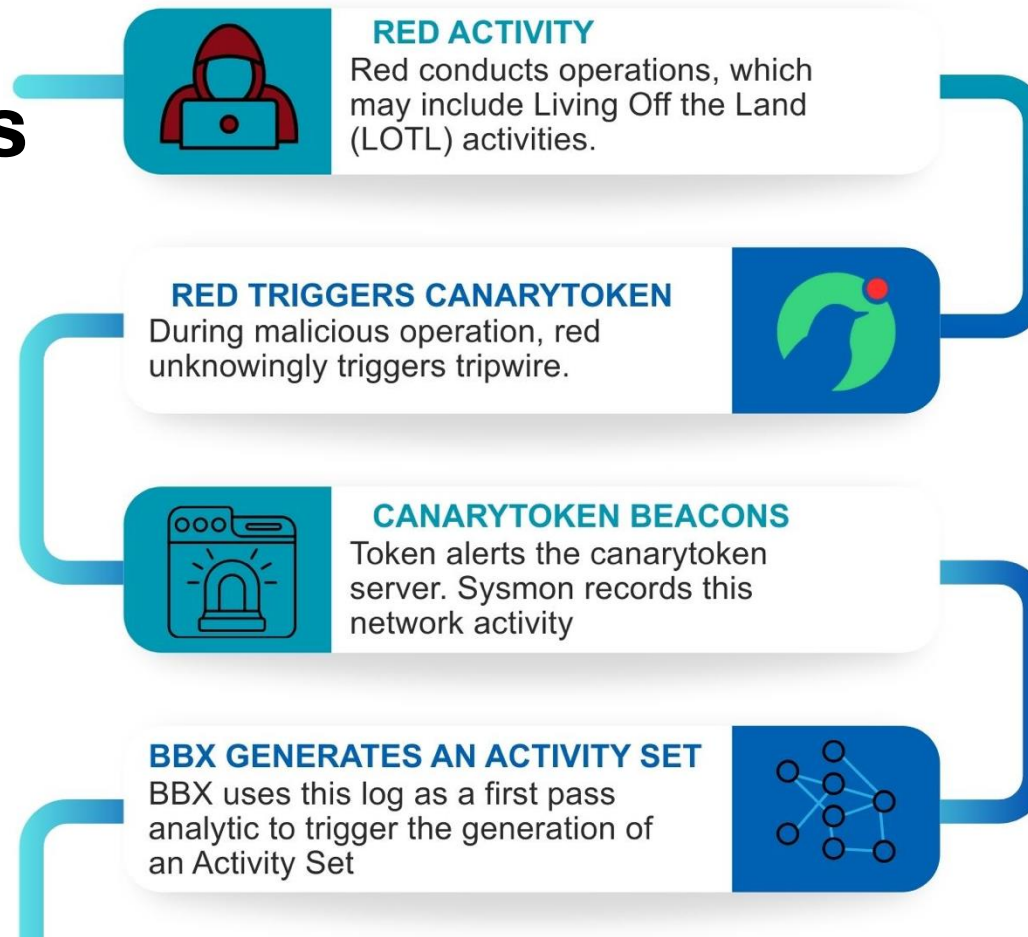
Use activity sets to visualize alerts



Use activity sets to visualize alerts



Use activity sets to visualize alerts



Use activity sets to visualize alerts



RED ACTIVITY

Red conducts operations, which may include Living Off the Land (LOTL) activities.

RED TRIGGERS CANARYTOKEN

During malicious operation, red unknowingly triggers tripwire.





CANARYTOKEN BEACONS

Token alerts the canarytoken server. Sysmon records this network activity

BBX GENERATES AN ACTIVITY SET

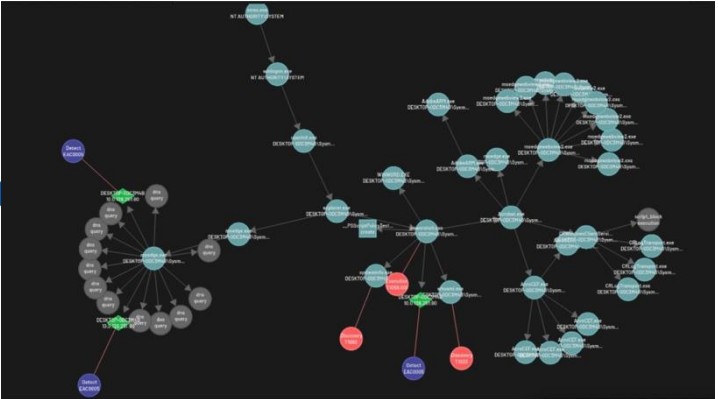
BBX uses this log as a first pass analytic to trigger the generation of an Activity Set





ACTIVITY SET VIEWABLE IN REY

Defender can now see an activity set, based on the activity surrounding the token, in Rey.

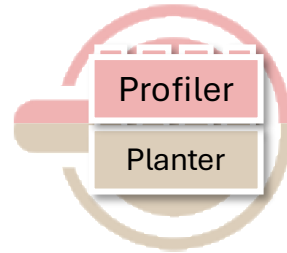


AXOLOTL Components: Overview



Caldera

Open-source adversary emulation platform



Artifact Dictionary

Map your IT assets, to ATT&CK, to Engage, to LOTLE opportunities.



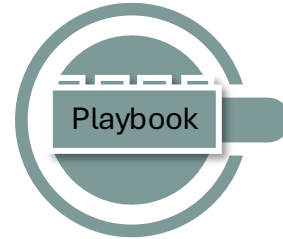
OpenCanary

Open-source tools to generate honeypots



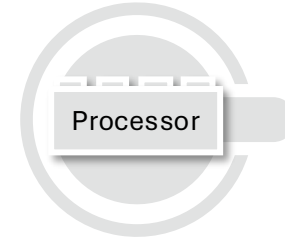
DECEIVE

Open-source AI honeypot to show how AI can lower the barrier to building realistic, high-fidelity honeypots



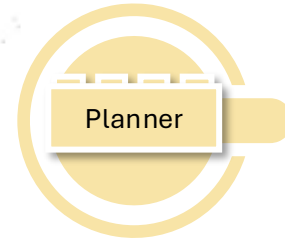
Canarytokens

Open-source tools to generate honeytokens



Blue Agave

Detect, label, and visualize ATT&CK-based attack activity through causal graphs



Engage Planning Process

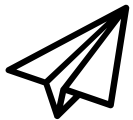
Set of resources to walk through the 10-step planning process



QUESTIONS?



engage.mitre.org



engage@mitre.org



<https://www.linkedin.com/showcase/mitre-engage>

**Thanks to everyone
who made this possible!**

Alice Koeninger

Ouwen Dai

Bronwyn Patrick

Austin Gibbons

Mark Perry

Ken Smith

Stan Barr

Chris Peloquin

Justin Bui

Sean Ha

Jake Steele

Baydan Hussen

Stephen Forbin

Mustafa Akpina